NATIONAL UNIFIED ELECTRONIC RECEIPT SYSTEM

DIGITAL TRANSACTIONS. A STRONGER PHILIPPINES.

NATIONAL UNIFIED ELECTRONIC RECEIPT SYSTEM

Technical Specifications & System Manual

Architecture • Security • Operations • Service Framework



SOFTWARE VERSION 1.0.0

Manual edition 1.0 | 19 October 2026

Implementation baseline and proposed operating plan.
Dataplugs, Contabo and AWS Singapore / Hong Kong are planned providers and regions, not a deployed architecture claim.

Contents

Controlled manual and reading guide 4

System purpose and boundaries 5

Technology and component inventory 6

System context diagram 7

Transaction acceptance sequence 8

Data-flow diagram 9

Acceptance, money and wallet controls 10

Idempotency and error recovery 11

Live, Sandbox and source eligibility 12

Logical data inventory 13

Data-lineage diagram 14

Lineage keys and reconciliation rules 15

Electronic documents and receipt emails 16

Merchant webhook protocol 17

Government transmission boundary 18

Planned hosting disclosure 19

Target hosting architecture 20

Data-residency and subprocessor register 21

Network zones and deployment controls 22

Security control baseline 23

Identity and authorization paths 24

Access model and segregation of duties 25

Login, sessions and multiple MFA devices 26

API credential lifecycle 27

Encryption and integrity matrix 28

Key hierarchy and separation 29

Contents / continued

Key rotation and recovery runbook 30

Audit integrity and evidence custody 31

Private uploads and document review 32

Privacy, retention and controlled deletion 33

Secure development and release procedure 34

Operational routines and worker inventory 35

Monitoring and online/offline semantics 36

Backup and recovery policy 37

Disaster-recovery sequence 38

Incident command and activation 39

Response workflow 40

Severity and first-response playbooks 41

Financial integrity and outage playbooks 42

Breach assessment and communications 43

Service catalogue and accountability 44

Proposed SLIs, objectives and budgets 45

Support, maintenance and service review 46

Merchant administration workflow 47

Administrator and finance workflow 48

Test strategy and acceptance evidence 49

Deployment readiness and risks 50

Operating approvals and ownership 51

Implementation source index 52

External reference register 53

Incident and recovery evidence forms 54

Glossary 55

Production notes and edition history 56

Controlled manual and reading guide

Technical baseline with clearly separated implementation and operating proposals.

Document field	Value
Software	NUERS - National Unified Electronic Receipt System
Software release / manual edition	1.0.0 / 1.0 | 19 October 2026 | Asia/Manila
Document ID	NUERS-TSM-1.0.0-20261019
Audience	System owners, implementers, security reviewers, operators, auditors and integration leads
Evidence scope	Local application source, supplied requirements and selected official reference material. No live infrastructure audit was performed for this manual.
Review status	Prepared technical baseline. Hosting allocation, service commitments and operating plans require management approval.
Distribution	Controlled technical reference. Contains no production credentials or customer records.

How to interpret the evidence labels

I - Implemented: behavior visible in the reviewed source. This does not prove that the same release is deployed or that every control has passed live testing. **P - Proposed:** an operating policy, design or target recommended in this manual. **V - Verify:** evidence required from deployment, contracts, tests or responsible personnel.

The owner confirmed that Dataplugs, Contabo and AWS Singapore/Hong Kong are intended future providers or regions and are not yet in use for the planned arrangement. Their roles are not represented as active infrastructure.

> Print as A4, actual size, duplex, flip on the long edge. Mirrored margins provide a wider binding edge. Keep this control page with any printed or bound copy; printed copies become uncontrolled when a newer edition is released.

System purpose and boundaries

A merchant transaction platform with separate identity, financial, delivery and regulatory concerns.

NUERS receives merchant transaction events, records accepted financial data, maintains electronic document views, tracks wallet charges and exposes status to merchant-owned ERP, POS and e-commerce systems. Merchant and administration portals provide controlled access to records, reviews, reports and integration settings.

Boundary	Technical meaning
Source capture	Preserves a copy of an original already issued by the merchant system, including its number, issue date and source identity. It does not allocate a second original invoice number.
NUERS issuance	Creates a new original only through the applicable issuance eligibility, authorization and numbering controls. Account activation alone is not issuance authority.
NUERS acceptance	A durable local result after validation and the financial database commit. A network acknowledgement and a delivered email are separate states.
Government transmission	Internal preparation and controlled delivery interfaces exist. The default provider is blocked; no operational BIR transport or accreditation is asserted here.

Architecture principles

- One accepted business event produces one financial result; retries return the stored result when the identity and content match.
- Live and Sandbox use credential-derived environments. Synthetic tests must not debit real wallets or become Live report entries.
- Database commits precede external delivery. Merchant webhook and customer email outcomes cannot roll back an accepted sale.
- Every privileged operation is checked at the server boundary; a hidden or disabled browser button is not an authorization control.

> This manual describes software behavior and proposed operations. It is not a certificate of accreditation, a penetration-test report, a hosting contract or an executed service-level agreement.

Technology and component inventory

Declared dependencies are a build baseline; deployed versions and patch levels require a release inventory.

Component	Reviewed baseline and responsibility
Backend	PHP ^8.2 and Laravel ^12.0. HTTP controllers, validation, authorization, transactions, scheduling and application encryption.
Web application	React 19.2.4; React Router 7.15.1; TypeScript ~5.9.3; Vite 7.3.1; Tailwind CSS 4.2.1. Merchant and administration interfaces.
Database	Relational data accessed through Laravel DB/query services. Production engine version, grants, storage encryption and topology are V items.
Queue / cache	Database queue is the configuration default. Shared cache and durable queue must be verified; Redis/SQS configuration support is not proof of use.
Document rendering	Shared document view, Node renderer and headless Chromium. Private temporary directory, network restrictions and cleanup support PDF creation.
Identity services	Registered-account password login, linked Google OAuth identity, device-bound human API session, TOTP devices and recovery codes.
External delivery	Merchant-controlled HTTPS webhook receiver and configured transactional mail provider. Each has independent delivery state.
Testing / build	PHPUnit ^11.5.50 declared. Frontend type/build tasks and document renderer build are present; a fresh test result must accompany each release.

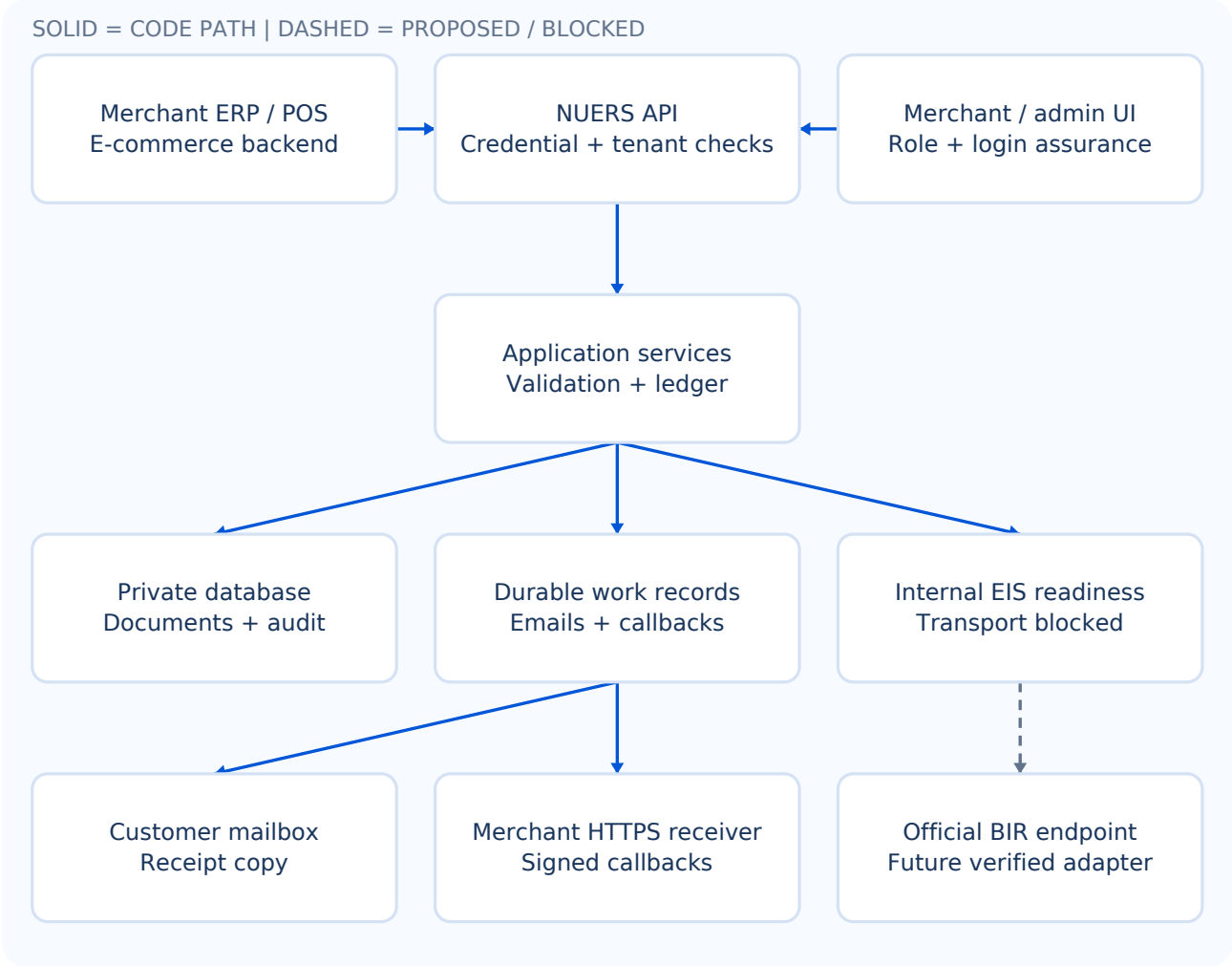
Configuration as an operational asset

Maintain a deployment bill of materials with exact lockfile versions, image or package digest, migration set, renderer binary version, environment name and release approver. Record feature flags and public URLs without copying secrets into the inventory. Keep application, worker and renderer releases compatible.

> Source: composer.json, package.json, config/queue.php, DocumentPdf.php and the build scripts. Version ranges above are declarations, not a claim that every hosting machine runs those exact versions.

System context diagram

D01 - Parties, application boundary, durable records and external recipients.



The central application mediates records and delivery. The dashed BIR path is conditional and blocked by the default provider.

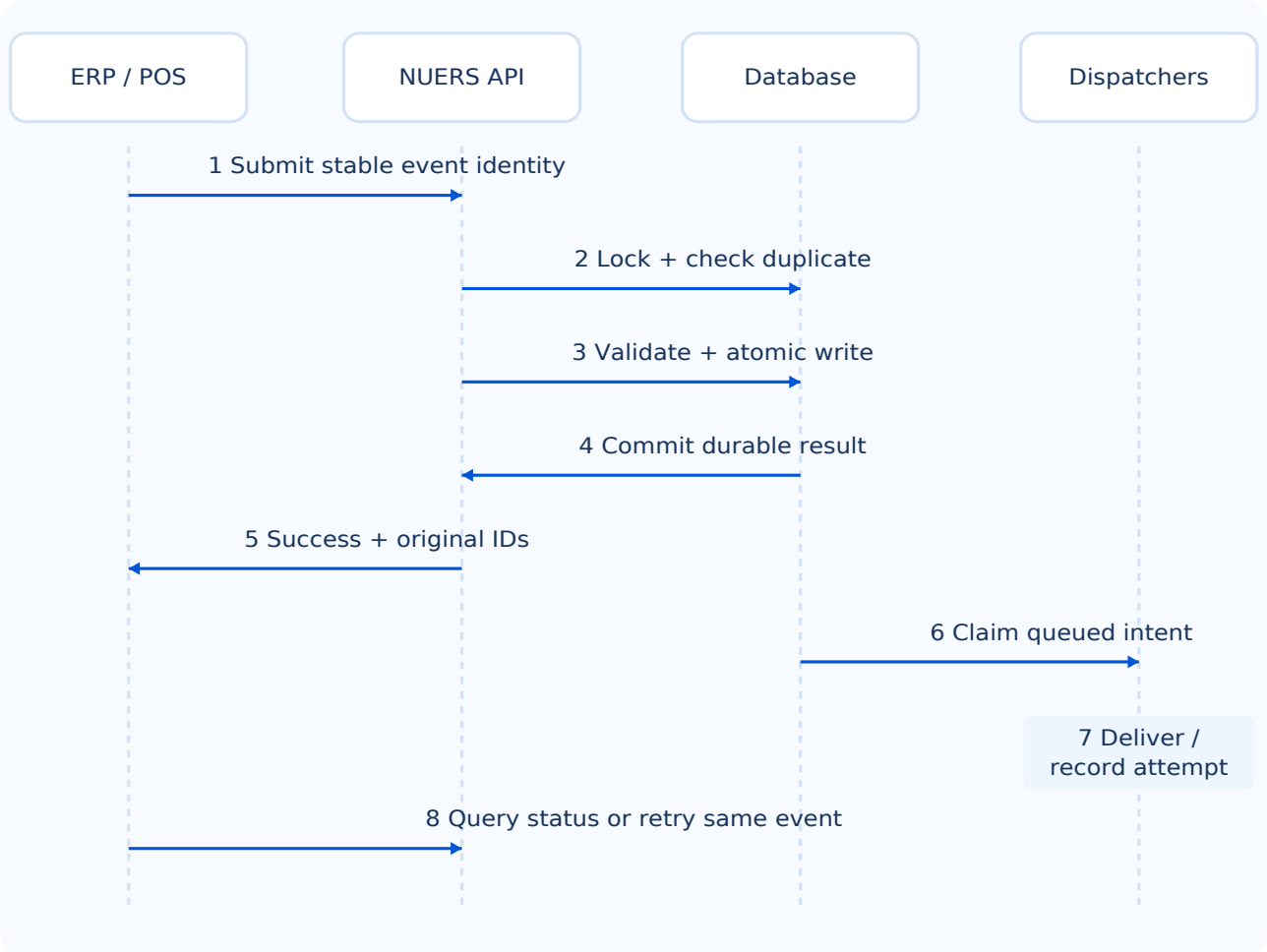
External systems submit server-to-server requests. Human users enter through a separate session and role boundary. Financial records and private documents remain behind the application. Delivery workers read committed intents and communicate only with the configured recipient systems.

Customer mailboxes and merchant callback receivers lie outside NUERS control. A successful callback or mail-server response proves a specific delivery step, not that a person opened the receipt. Official transmission must have its own authentic acknowledgement and evidence.

> I: logical application paths. P/V: physical placement, external provider activation, network perimeter and official transport.

Transaction acceptance sequence

D02 - The durable commit is the dividing line between intake and external side effects.



Sequence is simplified to emphasize commit ordering; all authentication and validation failures return before a new financial result is accepted.

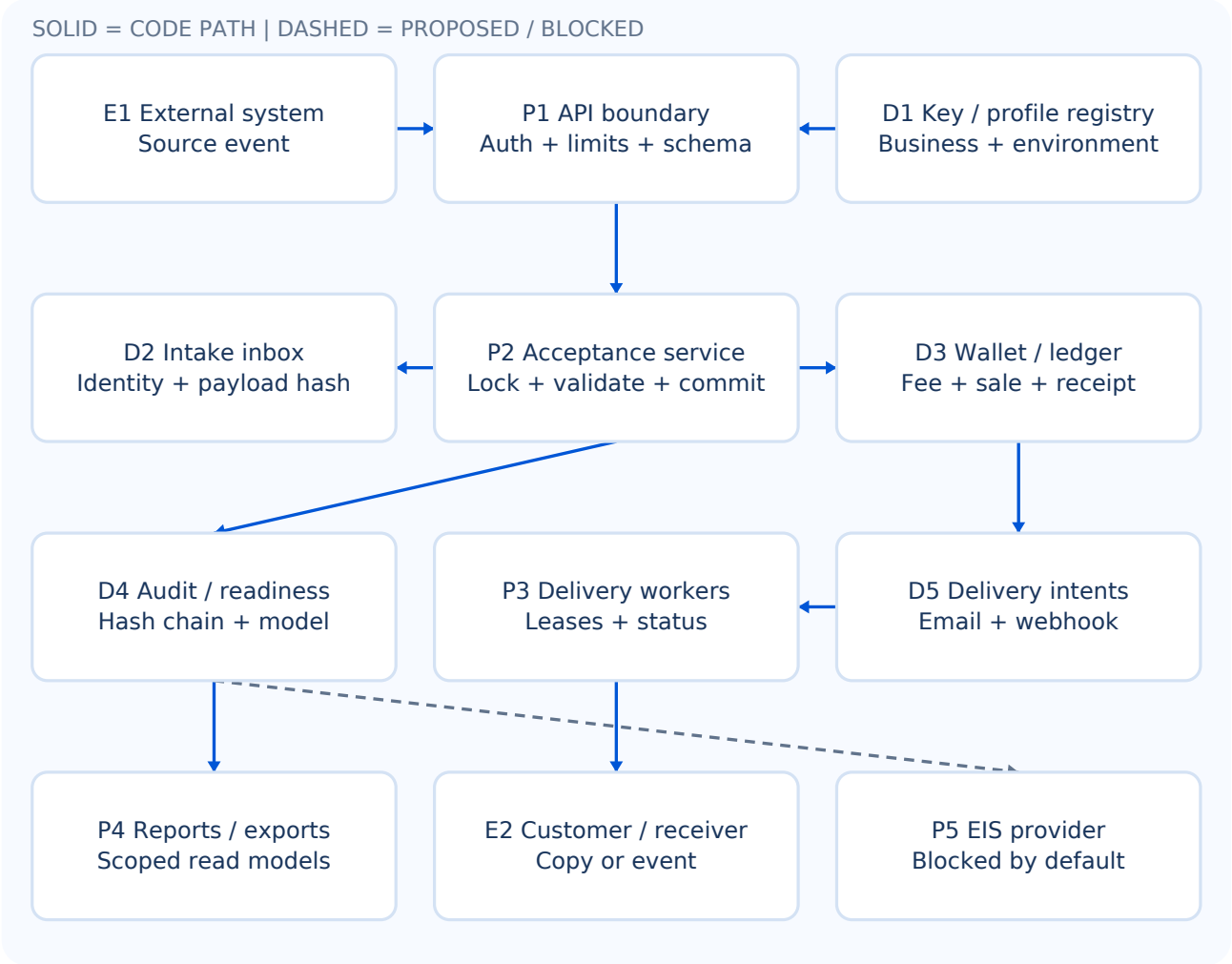
The connector should save its own outbound event before sending. NUERS checks the credential, environment, business context, request identity, payload and applicable financial rules. A stored identical event returns its original result. A new accepted event commits its records together before success is returned.

Email and webhook intents are dispatched asynchronously. If the response is lost after commit, retry the same event identity and unchanged payload or query its status. Never generate a new sale reference merely to overcome a timeout.

> I: IntegrationTransactionController, MerchantWallet, ApiCustomerReceipt and MerchantWebhooks. A client outbox is a connector responsibility; NUERS cannot make an external ERP commit atomic with its own database.

Data-flow diagram

D03 - Logical processes and stores; this is not a physical network diagram.



E = external entity; P = process; D = data store. Arrows show authorized logical movement rather than direct database access by clients.

P1 resolves authorization and rejects invalid requests. P2 owns acceptance and coordinates inbox, money, document and audit writes. P3 delivers committed notification work. P4 derives scoped reports. P5 keeps government delivery separate from merchant acceptance.

The same tenant identifier and environment context must survive every hand-off. Export and status endpoints must enforce these boundaries just as write endpoints do. A report row or receipt URL must never grant access solely because its identifier is known.

> Database and object-store security remain deployment responsibilities in addition to application checks. See the hosting and access sections for proposed network separation.

Acceptance, money and wallet controls

The fee policy is configurable; collection is tied to a new accepted Live primary sale.

The reviewed pricing service uses integer centavos. An administrator configures the fee and minimum transaction amount with a reason, revision control and audit evidence. The current default policy is a minimum of PHP 0.00 and a fee of PHP 3.00. A positive minimum exempts amounts strictly below that minimum; equality is chargeable.

Example policy	New finalized Live primary sale	Fee
Minimum PHP 0.00; fee PHP 3.00	PHP 100.00	PHP 3.00
Minimum PHP 500.00; fee PHP 3.00	PHP 499.99	PHP 0.00
Minimum PHP 500.00; fee PHP 3.00	PHP 500.00	PHP 3.00
Same accepted event retried unchanged	Stored result returned	No second debit
Supplementary payment copy	References an existing sale	No second sale fee
Sandbox event	Synthetic validation and records	No real wallet debit

Financial acceptance boundary

Under the tenant lock, the service checks funds before accepting a chargeable event. An insufficient-wallet response is HTTP 402 and must not create the new financial result or advance its issuance sequence. The wallet movement, transaction, receipt, intake record, readiness preparation and configured notification intents are coordinated by the acceptance workflow.

The gross sale amount used for threshold evaluation includes VAT where applicable and is evaluated before withholding deduction. Reporting must sum recorded fees rather than infer all revenue by multiplying row count by the current fee. Policy changes are prospective and do not rewrite earlier ledger entries.

> P: reconciliation should compare accepted primary sales, recorded fee entries and wallet balances daily. Escalate mismatches; never repair them by editing posted money rows directly.

Idempotency and error recovery

The integration protocol distinguishes a rejected request from an unknown delivery outcome.

Outcome	Connector action
201 - accepted	Save NUERS record identifiers and mark the source event successful. Acceptance follows durable recording.
200 - identical replay	Use the original result; do not count a new sale or add a second fee.
400 / 422 - invalid request	Show the validation reason to an authorized operator; correct the rejected event according to the source-system workflow.
401 / 403 - identity or access	Check expiry, revocation, scopes, account eligibility and configured restrictions. Do not expose the secret in logs.
402 - insufficient wallet	Show the reason and direct the merchant to fund the wallet. Retry the same event after resolution.
404 - status not visible	Check business, branch and environment. A cross-environment lookup must not reveal another record.
409 - conflicting identity	Stop automatic replay. Reconcile the original event and content; do not invent a reference to bypass the conflict.
429 / transient 5xx / timeout	Use bounded exponential backoff with jitter. Preserve the event and query or retry unchanged after an unknown outcome.

Stable source identity includes the merchant context, branch, source system and event/document reference. The service also compares canonical content. A copied source document keeps its original number and issue date; changing those fields is not a legitimate duplicate-avoidance technique.

The batch intake supports 1-50 complete events in one branch context and is designed for all-or-nothing acceptance. Apply request-size and item limits before transmission. A connector must not interpret the failure of a batch as evidence that a separately submitted event failed.

> I: schema NUERS-ingestion-1 and current integration contract. Exact field-level examples belong to the merchant connection guide and OpenAPI file; release both with the same application revision.

Live, Sandbox and source eligibility

The environment comes from the API credential, not a caller-controlled request field.

Control	Live	Sandbox
Financial records	Accepted business records	Separate encrypted synthetic records
Wallet	Real policy and available balance	Virtual simulation; no real debit
Numbering	Only authorized issuance path allocates originals	No production sequence mutation
Reports	Live business reporting	Separately identified test activity
Customer email	Queued when an eligible email is supplied	Suppressed
Webhooks	Only verified active Live endpoint	Environment-matched endpoint and test records
BIR path	Separate authority and provider gates	No production BIR delivery

Source capture and automatic setup

Verified active merchants can obtain default owned-system connection metadata and generate a secret API credential without a separate approval of that default connection. The merchant portal exposes the assigned source profile and source-system identifier. Existing source identities and historical records remain controlled.

Automatic setup is not a blanket approval for historical originals outside the profile scope, another seller, or new government-authorized issuance. A historical-source review remains distinct where required. The server derives the registered establishment context; removing a merchant-facing Branches / Terminals page does not remove backend identity checks.

> P: use separate ERP outbox namespaces, receiver secrets and monitoring labels per environment. Test migration and reporting queries for environment leakage before each release.

Logical data inventory

Inventory categories support ownership, retention, access review and recovery scoping.

Data domain	Typical contents and purpose	Classification
Identity / access	User account, normalized email, role, token hash, MFA device records and recovery-code digests	Restricted
Merchant registration	Business identity, TIN, address, owner/representative, review decisions and evidence	Confidential / restricted evidence
Integration registry	Credential hash, scope, expiry, environment and source profile	Restricted
Financial records	Accepted transaction, line items, taxes, discounts, document identities, wallet debits and deposits	Confidential
Private documents	Verification files, filenames, checksums, version history and review notes	Restricted
Delivery records	Encrypted customer recipient, webhook endpoint/secret/body, attempts and outcome metadata	Restricted
Audit and operations	Actor, event, subject, time, hash-chain linkage, incident and recovery evidence	Confidential / restricted
Presentation / analytics	Dedicated receipt logo, settings, scoped reports and derived dashboard totals	Business-controlled; exports confidential

The logical inventory is not an assertion that every column is encrypted. Selected sensitive fields and private document contents use application encryption. Database-wide, volume and backup encryption require separate infrastructure evidence.

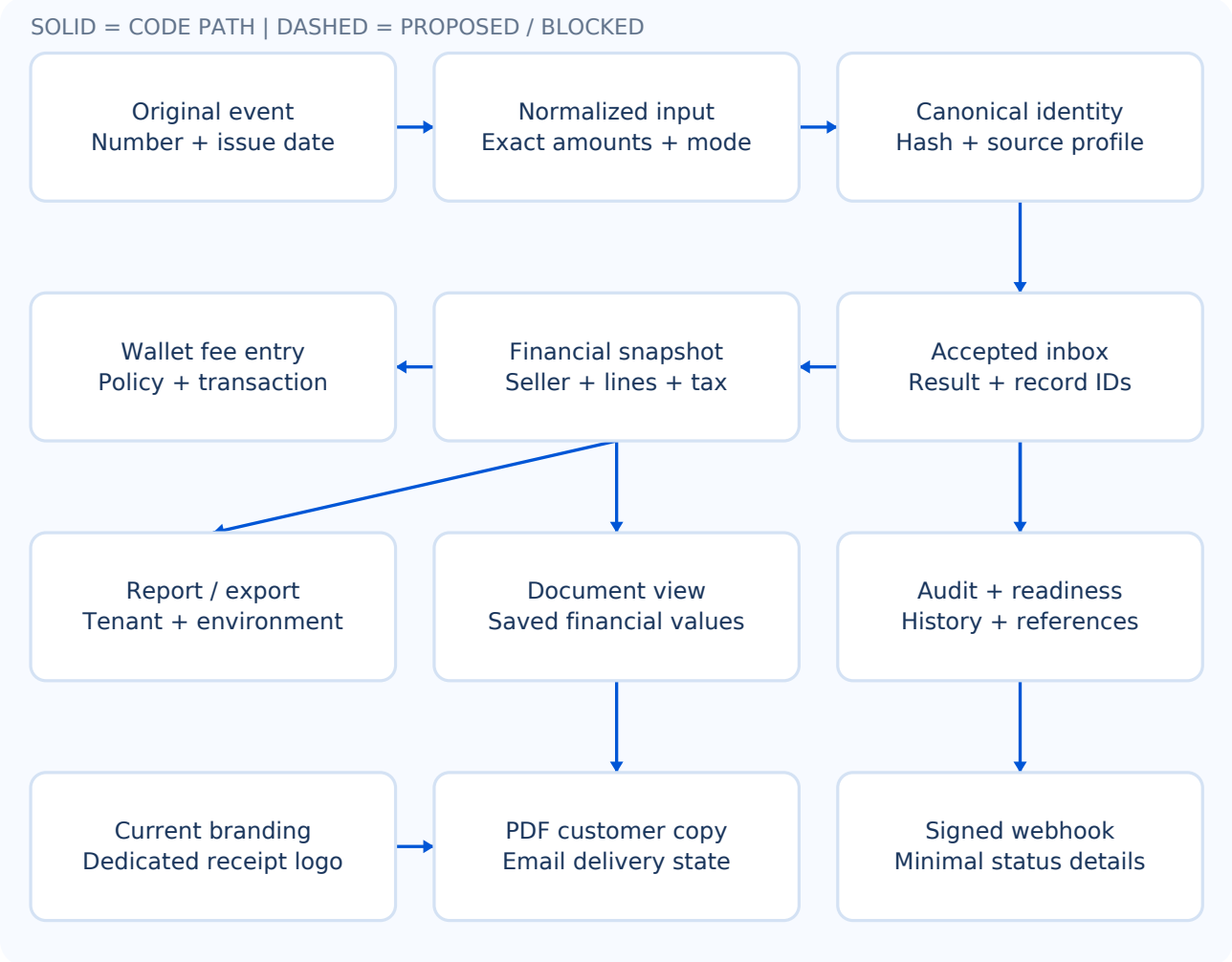
Data stewardship

Assign a business owner and technical custodian to each domain. Maintain a record of processing purposes, approved readers, retention basis, export destinations and deletion restrictions. Include support systems, backup copies and provider logs in the inventory. Never use unrestricted production data as a test fixture.

> P: approve a classification policy before broad external distribution of exports. The labels in this manual are a proposed handling baseline.

Data-lineage diagram

D04 - Follow the original event into financial, presentation, delivery and report outputs.



Financial provenance and visual branding are separate branches. Current document copies may use current saved branding while retaining original seller, items and financial values.

A source event is normalized and bound to a stable identity and content hash. The accepted inbox result connects external references to NUERS transaction and receipt identifiers. Wallet entries and audit events allow a reviewer to trace the acceptance without recomputing history from today's settings.

Reports are derived views, not new financial originals. A webhook carries limited status metadata rather than customer details or receipt imagery. A customer PDF is a rendered copy whose email-delivery status is tracked independently.

> I: ElectronicDocumentView applies current saved visual branding to document copies. P: when exact rendered-copy reproducibility is required, retain an authorized PDF artifact, its hash, render timestamp and branding revision.

Lineage keys and reconciliation rules

Identifiers must stay linked across operations, investigation and customer support.

Origin / key	Transformation or linkage	Verification
source_event_id + external_reference	Stable external event/document identity within the scoped source	Unchanged retry maps to original accepted IDs
source_profile_id + source_system	Seller and owned-system context; scope and effective period checks	Reject conflicting seller, scope or unsupported historical period
Canonical payload hash	Normalized input compared for duplicate/conflict decisions	Same identity + changed content is a conflict
NUERS transaction / receipt IDs	Intake result links to financial snapshot and document view	Status, report and document resolve to the same tenant
Wallet movement	Fee charged under the policy used at acceptance	Opening + credits - debits reconciles to closing balance
Audit event / chain head	Actor, action, subject, timestamp and previous hash	Chain recomputation and independent checkpoint match
Delivery ID / event ID	Email or webhook attempt references committed subject	Retries do not create a new financial event
Export filter context	Environment, business, dates and sales category bound to output	Displayed/exported totals reconcile to the same selection

Time and financial precision

Carry an explicit offset on external event timestamps. Preserve the original business occurrence time separately from ingestion, commit, review and delivery times. Use UTC for event ordering where implemented and label Philippines business views as Asia/Manila. Reconcile using integer centavos and documented rounding, not floating-point approximations.

> P: a reconciliation evidence pack should record the query period, timezone, environment, record counts, monetary totals, exceptions, reviewer and export hash. Do not place full buyer identifiers in a general incident ticket.

Electronic documents and receipt emails

The receipt uses its own branding configuration, independent of the merchant profile image.

The profile image identifies the business in portal and registry views. Invoice Settings maintains a dedicated receipt logo plus template, colors, font, footer and related presentation options. The shared document view preserves recorded seller identity, items and totals while applying current permitted visual branding to copies.

Customer email flow

- The accepting Live API workflow reads the supplied customer email and creates a document-email delivery record and notification intent inside the accepted-sale transaction.
- The recipient is encrypted. The asynchronous worker renders the shared e-receipt PDF and sends through the configured mail transport. SMTP is not performed in the intake request.
- Sandbox returns a suppressed email state. Missing customer email returns not_requested. An accepted sale remains accepted if later mail preparation or delivery fails.

Delivery state	Meaning and response
queued / preparing / sending	Work is in progress; do not promise inbox delivery.
smtp_accepted	The mail server accepted the message. This is not proof of customer receipt, reading or absence of a later bounce.
uncertain	Outcome cannot be confirmed; investigate before resending to avoid duplicates.
failed / expired / cancelled	Use the recorded reason and an authorized resend/copy workflow after the cause is resolved.

The PDF service uses a private temporary directory and an isolated Chromium profile. It passes only an allowlisted process environment, renders vetted content with network access restricted and removes temporary files in cleanup. Runtime availability and sandbox operation must be verified on the actual host.

> P: establish the mail provider, sender-domain authentication, bounce handling, retention and data-location register before external customer delivery is relied on operationally.

Merchant webhook protocol

Signed notifications provide asynchronous status; the receiver must still deduplicate.

The owner configures a public HTTPS callback for the appropriate environment. Endpoint verification uses a challenge; a successful verification leaves it paused until activation. Configured events include transaction.accepted, source.received, invoice.issued and payment.recorded. Secrets are separate from API credentials and versioned.

Protocol / safeguard	Reviewed behavior
Signature	HMAC-SHA256 over timestamp + "." + event_id + "." + raw_body; X-NUERS-Signature contains the v1= prefix.
Headers	X-NUERS-Event, X-NUERS-Timestamp, X-NUERS-Environment and X-NUERS-Key-Version accompany the JSON event.
Destination	Public DNS hostname, HTTPS port 443, no credentials/query/fragment, no NUERS self-callback. All resolved addresses checked against private/reserved ranges.
Transport	DNS resolved again and pinned; certificate/hostname validation on; no proxy or redirect fallback; 3-second connect and 8-second total timeout; response limited to 16 KiB.
Durability	Encrypted body and SHA-256 content hash; leased attempts. Retry budget is 12 attempts within the ordinary one-day deadline, with exponential delay and jitter.
Stop conditions	Redirects and selected permanent HTTP rejections dead-letter; changed/revoked endpoint or account can cancel pending work.

The receiver should verify the signature against the exact raw request body, enforce an agreed timestamp tolerance, compare signatures in constant time and persist the event ID before acknowledging. Return 2xx after durable receipt, then process internally. Duplicate callback delivery must be harmless.

> I: current merchant webhook services. P/V: the merchant receiver and a real end-to-end delivery test. Callback payloads intentionally omit customer details, monetary amounts, secrets and document images.

Government transmission boundary

NUERS receipt, readiness and official acceptance must remain distinguishable.

The current merchant API exposes NUERS success or an error reason. Its accepted response strips bir_status and related internal BIR preparation fields. This simplifies the connector contract without converting a local success into a government acknowledgement.

Stage	Evidence and operational treatment
Local acceptance	Stored financial result and NUERS identifiers. Safe to report as recorded by NUERS after success.
Internal preparation	Readiness model and source/authority checks; this is not a verified government wire message.
Delivery eligibility	Current taxpayer, branch, environment, authorization, source coverage and solution controls must pass.
Official transport	The reviewed default BlockedProvider returns not ready and refuses send/inquiry. A verified adapter and credentials are required before enabling a real path.
Official acknowledgement	Only an authentic provider response/inquiry can establish the relevant external outcome. Never fabricate acknowledgements to clear a dashboard.
Unknown outcome	Reconcile by authentic inquiry before replay. Preserve the job, evidence and prior attempt history.

Operational release gate

A future transport release must identify the authoritative interface specification, mapping tests, signing/certificate requirements, authorized endpoint, taxpayer scope and reporting obligations. Review duplicates where source originals may already have been reported through another system. Keep credentials out of screenshots and source control.

The delivery and reconciliation commands expose internal work and incident reminders. Their existence does not prove a running scheduler or a successful external transmission. Operators must inspect recorded outcomes and preserve the provider evidence.

> V: accreditation, authority, live transport, service credentials and provider acknowledgements. This manual makes no representation that these have been granted or independently verified.

Planned hosting disclosure

Owner-confirmed planning status: the named providers and regions are not yet in use for this planned arrangement.

Provider / region	Disclosure and decision still required
Dataplugs	Planned candidate. Official material lists Hong Kong facilities. Exact contracted facility, product, tenancy, role, support access and data placement must be selected and recorded. [R2]
Contabo	Planned candidate. Public provider material describes Singapore availability; exact order location, current service availability and recovery capability require procurement confirmation. [R3]
AWS Singapore	Planned region ap-southeast-1. Decide whether used for compute, backup, logs or recovery; none is asserted as deployed. [R1]
AWS Hong Kong	Planned region ap-east-1. Region enablement and each required service must be checked before provisioning. No cross-region replication is asserted. [R1]
Current production location	Not independently established by this manual. Prior UI addresses or a provider hostname are not sufficient evidence of the current data residency or topology.

Decision principles

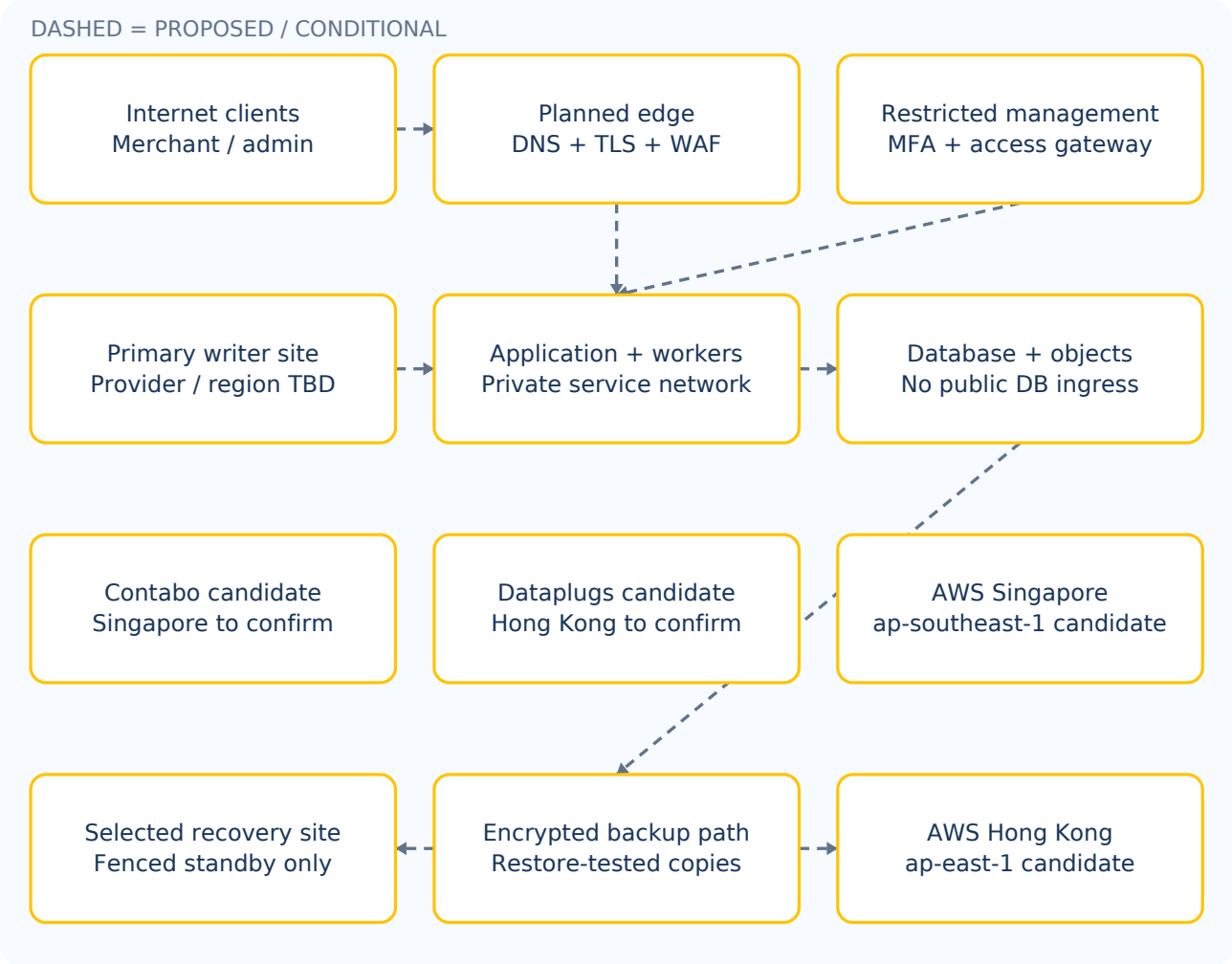
Choose one authoritative primary database writer and a documented recovery site. Do not distribute active writers across providers without an explicitly engineered consistency and failover design. A lower-cost compute provider can be combined with independently managed backups, but the team must own network, database, key and restore operations.

Complete procurement, privacy review, region restrictions, provider access terms, monitoring, backup restoration and failover drills before declaring the proposed design operational. Provider certifications or facility features do not automatically certify the NUERS workload.

> P: the following design is a decision framework, not an approved allocation. No migration, provider purchase or production configuration change was performed to prepare this PDF.

Target hosting architecture

D05 - Proposed roles and candidate locations; all dashed paths require implementation and evidence.



Provider candidate boxes do not indicate that all four locations host production copies. Assign each actual role in an approved deployment register before enabling data movement.

The primary site contains the authoritative database, private objects and application services. A separate recovery site receives approved encrypted backups or replication. Independent backup custody reduces the risk that a compromised primary administrator can destroy every recoverable copy.

Cross-provider transport needs authenticated encryption and restricted routes. Recovery promotion must fence the former writer and pause side-effect workers. Singapore and Hong Kong placement must be deliberate for databases, backups, logs, keys and support access, rather than inferred from the application URL.

> P: no active-active database, automatic regional failover, cloud KMS integration or immutable offsite copy is claimed as implemented by this diagram.

Data-residency and subprocessor register

Record the location of every copy, not only the application server.

Asset / processor	Location decision and required evidence
Production database	Primary provider, facility/region, account/project ID, replica locations, engine, encryption and administrative access. Status: V.
Verification documents / receipt assets	Storage backend, object region, temporary render location, replication and public-access restrictions. Status: V.
Backups / transaction logs	Source and destination regions, schedule, retention, object lock, key location, restore record and deletion method. Status: P/V.
Application / security logs	Collector and archive regions, redaction, retention, provider access and query permissions. Status: P/V.
Secrets / recovery keys	Custody platform, region, administrators, break-glass mechanism and key recovery evidence. Status: P/V.
Transactional email	Mail provider, processing/storage locations, delivery logs, subprocessors, retention and sender authentication. Status: V.
Google identity	Identity provider and data exchanged; document applicable contractual and privacy disclosures. Tokens and identifiers require controlled handling.
Merchant webhook receiver	Merchant-selected public endpoint and environment. The merchant controls the destination; NUERS must enforce endpoint and payload restrictions.
Support / monitoring tools	Ticket attachments, traces, analytics, remote access and any copied personal data must be included. Status: V.

The accountable owner should sign the register before activation and after every provider, region or subprocessor change. Attach a data-flow record, contract/DPA reference, security review, deletion/exit procedure and access owner. Do not include credentials in this register.

> P: cross-border processing requires a documented privacy and contractual review. No conclusion of legal compliance is inferred merely from selecting Singapore or Hong Kong.

Network zones and deployment controls

Proposed infrastructure baseline to support the application controls.

Zone	Allowed flows and controls
Public edge	HTTPS client traffic to approved web/API routes. Configure certificates, request limits, rate controls and WAF rules; restrict direct origin bypass.
Application	Only edge-to-app traffic on documented service ports. Dedicated service identity; no cloud/root administration from the runtime.
Data	Database and cache reachable only by authorized services and controlled maintenance access. No public database listener.
Private objects	Tenant-authorized application reads; no anonymous verification-document URLs. Limit backup writers and readers separately.
Workers / egress	Only required mail, approved callback and future authorized provider traffic. Monitor destination changes and failed egress.
Administration	Named accounts, MFA, controlled access gateway, time-bounded privilege and audit trail. Avoid shared Plesk/root identities.
Recovery	Isolated restore validation with outgoing mail, callbacks and government delivery disabled until reconciliation and cutover approval.

Before multiple application nodes are introduced, verify shared storage behavior, distributed locks, atomic quotas, scheduler exclusion and worker leases. A filesystem that is local to one machine is not automatically available to another. Choose a tested object/storage adapter and migration approach before moving private files.

TLS 1.3 should be preferred and TLS 1.2 retained only where necessary; disable legacy protocols and weak cipher configuration. Verify every TLS hop, including database and provider connections, at deployment. Application HSTS and certificate checks do not establish the edge cipher configuration. [R6]

> P/V: infrastructure hardening, origin access, firewall rules, TLS scans, shared-service topology and administrator access evidence.

Security control baseline

Application evidence is distinct from infrastructure assurance and independently tested effectiveness.

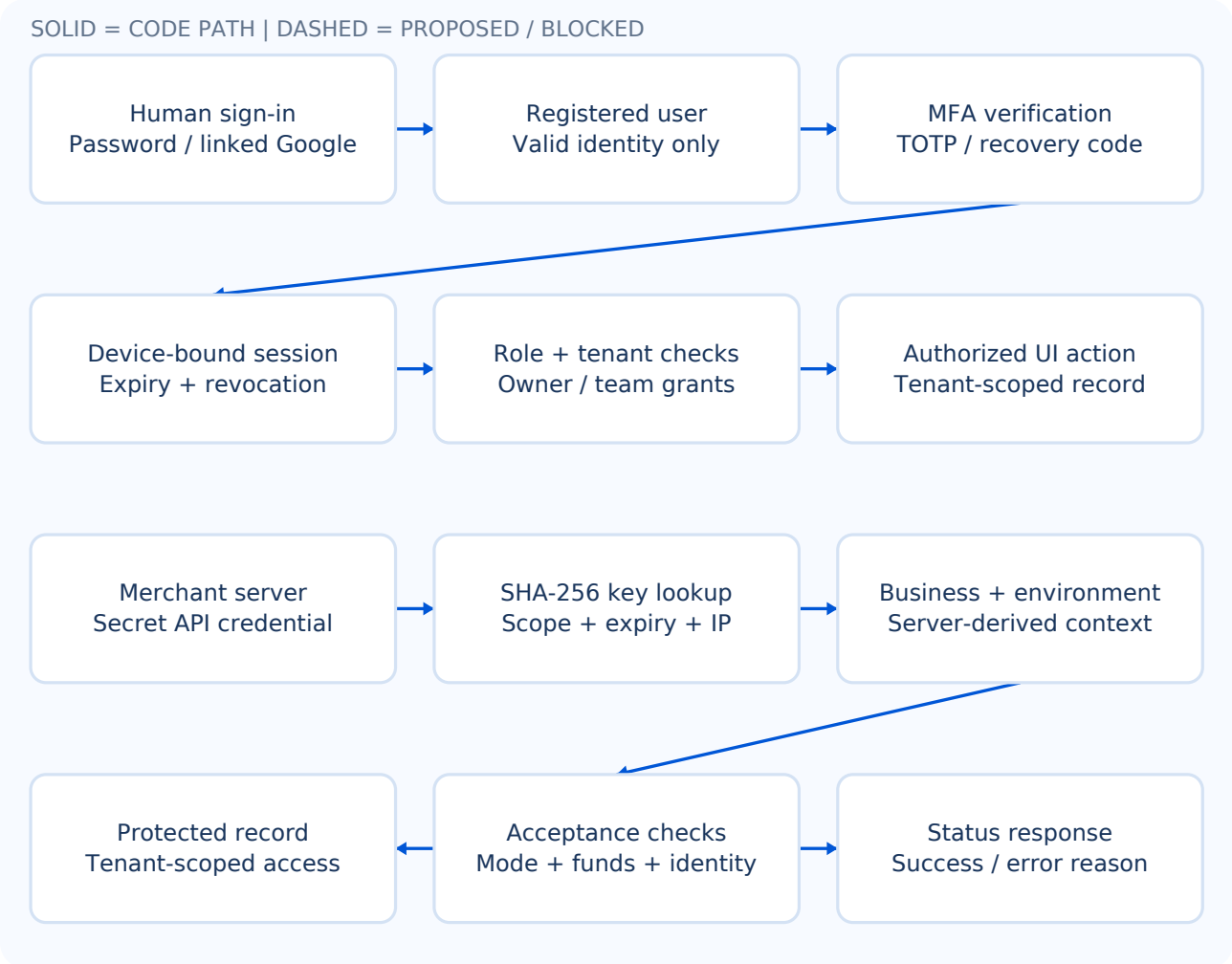
Control area	Reviewed implementation	Evidence still required
Identity	Registered user checks, linked Google identity, token hashes and device binding	Production configuration; account/role review
MFA	TOTP devices, replay counters and single-use recovery codes	Enrollment coverage; recovery drill
Tenant access	Server-side role, merchant and team scope checks	Negative cross-tenant tests for every route/export
Application encryption	Laravel Crypt on selected sensitive fields and private file frames	Key custody; host/DB/backup encryption
API integrity	Strict schema, canonical identities, durable inbox and duplicate handling	Concurrency, replay and failure-injection tests
Outbound webhooks	Signed events, destination validation, DNS pinning and bounded transport	Real merchant receiver verification and test
Browser hardening	CSP, frame denial, nosniff, no-referrer and private API cache headers	Observed deployed headers and TLS behavior
Audit	Hash chain and separately keyed checkpoint command	Independent custody and restore verification
Recovery	Evidence-oriented recovery dashboard and workflow	Actual backups, independent restores and measured recovery
Threat detection	Application records and operational reminders	Central alert routing, on-call response and tested detections

Run security tests against both successful and rejected operations. Test object-level authorization, identifier guessing, role downgrade, revoked keys, stale sessions, altered payloads, duplicate events and unauthorized export requests. Review custom browser token handling and device storage against the XSS threat model.

> P: use a documented risk register with owners, severity, compensating controls and expiry dates. The presence of a control in code is not a substitute for independent security testing.

Identity and authorization paths

D06 - Human authentication and machine integration use different credential lifecycles.



A verified login permits only actions allowed by role, ownership, team grant and business state. Machine credentials do not inherit an administrator session.

Human access is resolved to a registered user and role, then scoped to the target business and action. MFA assurance attaches to the current login. Machine requests use a separate hashed API credential with environment, scope, expiry and applicable network restrictions.

Account activation, document review, integration metadata creation and permission to issue a new original are distinct decisions. The interface should explain an unmet condition, while the backend enforces it. Changing presentation or navigation must not remove a security boundary.

> I: ApiAccess, ApiBoundary, MerchantTeamAccess and merchant key/context services. P/V: an approved role-permission catalogue and periodic access certification.

Access model and segregation of duties

Recommended role governance layered on the implemented role and tenant checks.

Actor	Permitted responsibility	Separation requirement
Merchant owner	Business-owned settings, key generation, authorized team grants and wallet visibility	Cannot grant government authority or view another merchant
Merchant team member	Only assigned business functions and scope	No implicit owner credential-management rights
NUERS reviewer	Review documents and proposed identity corrections within assigned authority	Retain evidence, reason and actor; avoid reviewing own changes
Finance operator	Reconcile deposits, wallet movements and fee policy under authorized workflow	Separate approval of adjustments from preparation
Security administrator	Account access, incident containment and security configuration	No unreviewed rewriting of financial history
Platform operator	Deployments, monitoring, backup and recovery operations	No routine unrestricted customer-data access
Auditor / reviewer	Read evidence and scoped exports as authorized	Read-only by default; no operational credential reuse
Service identity	A bounded application, queue or integration task	No interactive human login; least privilege and rotation

Joiner, mover and leaver procedure - proposed

Register the person, accountable manager and approved role. Confirm identity, enroll MFA where required, grant the minimum scope and record approval. When duties change, remove old grants before adding new ones. On departure or suspected compromise, revoke sessions and keys, remove team grants, reassign operational ownership and verify that access is denied.

Review privileged access monthly and all business/service access quarterly as an initial policy. Use a controlled emergency account with named custody, explicit incident linkage and post-use review. Fill the roster with actual people before the service framework is adopted.

> P: two-person approval and review frequencies are governance recommendations unless a particular server workflow already enforces them.

Login, sessions and multiple MFA devices

Once-per-login assurance remains subject to expiry, revocation and permission checks.

Google sign-in is restricted to a verified email that matches a unique existing registered account. A linked stable Google subject must also match. New identity linking is limited by the implemented Gmail or verified Workspace checks. OAuth state and a short-lived single-use handoff protect the exchange; successful OAuth is followed by NUERS MFA where required.

Mechanism	Reviewed behavior
Human API token	SHA-256 lookup, expiration and absolute-session checks. X-NUERS-Device is compared to the stored device digest. Missing device binding is denied outside tests.
Session assurance	The current verified login carries MFA assurance; routine actions do not trigger a repeated 15-minute challenge. A new login, expiry or revocation requires the applicable checks again.
Authenticator	Six-digit TOTP; 160-bit random secret; 30-second step; current/adjacent step window; accepted counter must be newer than the prior counter.
Multiple devices	Up to five independent TOTP devices; each has its own encrypted secret and replay state. Adding/removing requires the implemented password and existing-factor/recovery controls.
Setup / recovery	Pending setup expires after ten minutes. Recovery codes are account-level, hashed and single-use. The final active authenticator cannot be removed through the normal device-removal flow.

Session timeout values are configurable. The reviewed human API policy defaults differ from Laravel cookie-session defaults; record both effective configurations rather than treating them as one timeout. Multiple authenticators are not permission to share a login or a guarantee of concurrent independent browser sessions.

> P: require recovery identity checks, owner notification and revocation review. Never ask a user to send an authenticator seed, current code or recovery code in a support ticket.

API credential lifecycle

Issue a secret for a specific integration and environment; show it once and store only its digest.

The merchant creation flow collects the integration name and environment. The server assigns the registered business context and checks the verified owner login and active account. The generated secret uses a NUERS environment prefix and random material; the application stores a SHA-256 digest for authentication rather than a recoverable API secret.

Lifecycle step	Required practice
Create	Use a descriptive system name. Keep Live and Sandbox credentials separate. Confirm business/source context and allowed actions.
Store	Copy the one-time secret to the merchant backend secret store. Never embed it in browser JavaScript, mobile bundles, repositories, URLs or receipts.
Constrain	Apply available permission and exact-IP restrictions. Defaults include transaction read/write, 90-day expiry and daily limits of 50,000 for Live or 5,000 for Sandbox. Limits are not capacity guarantees.
Use	Send over HTTPS in the documented header or bearer form. Conflicting authentication forms are rejected. Preserve response IDs and sanitized errors.
Rotate	Create a replacement, update the controlled connector, confirm status/acceptance using the right environment, then revoke the old key. Track both owners and expiry dates.
Revoke	Immediately disable suspected or retired credentials. Review recent events and callback destinations; do not delete financial evidence.

The current merchant connection is a secret-key protocol. This manual does not invent a merchant public/private signing-key pair or imply that API keys are government signing certificates. Webhook signing secrets and future provider-issued credentials have separate purposes and custody.

> P: alert before expiry, inventory keys by owner and integration, and test revocation propagation. Do not run a Live financial test solely to confirm that a credential was issued.

Encryption and integrity matrix

Encryption, hashing and signatures solve different problems and need different recovery procedures.

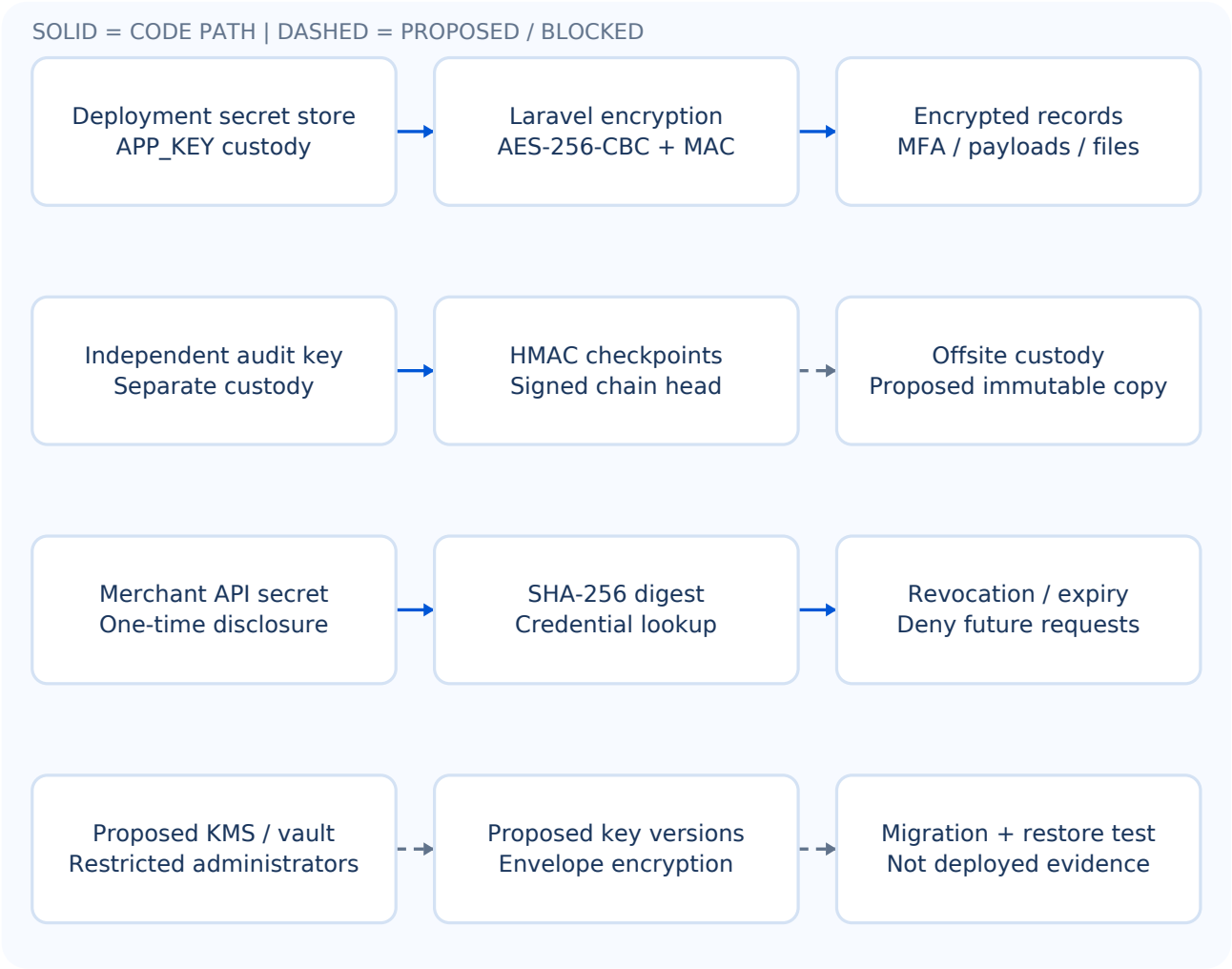
Asset / channel	Current mechanism	Limit / operational requirement
Selected sensitive fields	Laravel Crypt; configured AES-256-CBC with framework authentication/MAC	Protect APP_KEY; not every database column is encrypted
Private verification files	Authenticated encrypted frames of up to 1 MiB; length and SHA-256 checked before exposure	Protect private storage and temporary plaintext space; retain matching metadata
Passwords	Framework password hashing through Hash facilities	Record effective algorithm/work factor; test upgrades without weakening existing hashes
Human / merchant tokens	SHA-256 credential digest comparison	High-entropy secrets; hash is not a backup of the original secret
MFA seeds	Reversible application encryption for TOTP verification	Restrict secret access and erase expired setup material
Recovery codes	Hashed, single-use account recovery values	Original codes must be retained privately by the user
Webhook event	HMAC-SHA256 with a versioned callback secret; encrypted stored body	Receiver verifies raw bytes, event ID and timestamp; no public-key certificate claim
Audit checkpoint	Independent HMAC-SHA256 key over checkpoint evidence	Separate custody and offsite verification required
Network / disks / backups	HTTPS use/checks in application; host-wide encryption not established	V: TLS termination, database transport, disks, backups and key-service settings

SHA-256 detects a content mismatch or permits comparison of a high-entropy token digest; it does not conceal ordinary personal information. HMAC authenticity depends on key secrecy. Application encryption cannot protect plaintext while it is legitimately processed by the running application or prevent misuse by an overly privileged operator.

> P: maintain a cryptographic inventory with algorithm, purpose, key owner, location, creation/rotation dates, dependencies and recovery test evidence.

Key hierarchy and separation

D07 - Current application keys and proposed managed-key evolution.



The lower row is a proposed future design. The current application uses Laravel encryption; no deployed cloud KMS envelope-encryption integration is asserted.

APP_KEY enables decryption of application-protected data. The audit checkpoint key should have separate custody so that a database/application compromise does not automatically control independent checkpoint verification. API secrets are verified by digest, while webhook secrets must be recoverable for signing.

A future vault or KMS design must define service identities, key policies, region placement, audit access, emergency recovery and migration compatibility. Moving a key into a cloud console without updating the application and restoration process does not establish a managed-key architecture.

> P/V: deployment secret storage, separate administrators, automated secret delivery and tested recovery of each encryption dependency. Never print keys in this manual or in a provider inventory.

Key rotation and recovery runbook

Preserve decryptability while reducing exposure; never replace APP_KEY casually.

Phase	Procedure and evidence
1. Inventory	Identify data protected by the key: MFA seeds, private files, sensitive payloads, endpoint secrets and mail recipients. Record current version references without exposing values.
2. Prepare	Verify an encrypted backup and independent recovery path. Restrict access to key material. Test rotation against a representative isolated copy and all dependent services.
3. Introduce	Use a reviewed versioned-key rollout. Laravel supports previous application keys, but effective configuration and every data format must be tested. Keep old decryption available during transition.
4. Re-encrypt	Migrate data in bounded, restartable batches with audit evidence. Verify a sample and aggregate counts. Avoid reading secrets into general application logs.
5. Validate	Test document retrieval, MFA, callback signing, email rendering and restore operations. Confirm new writes use the intended key version.
6. Retire	Retire an old key only after all required retained data and backups have a viable decryption path or approved expiry. Record approver, date and destruction evidence.

Compromise response

If an application key may be exposed, treat confidentiality of all data protected by it as potentially affected. Isolate the cause, preserve evidence, revoke compromised access and determine which data was accessible. Coordinate credential rotation and privacy review. Rotation alone does not undo prior disclosure.

Maintain a sealed or independently controlled recovery method with at least two authorized custodians under the proposed policy. Test recovery without publishing the key or restoring outbound delivery into an uncontrolled environment. Loss of a required decryption key can make a technically intact backup unusable.

> P: this is a proposed operating procedure, not an automated rotation feature or evidence that a key ceremony has already occurred.

Audit integrity and evidence custody

A hash chain is tamper-evident evidence, not independent immutable storage by itself.

BirCompliance appends audit events under a locked chain head. The event hash includes the previous hash, event name, subject, actor, serialized details and UTC timestamp. Integrity verification recomputes the chain and compares the final head. This helps detect changes relative to a trusted reference.

The checkpoint command verifies the chain and signs a checkpoint using a separately configured HMAC key. Its local file is not automatically an offsite immutable record. An attacker with sufficient database and application-key privileges could otherwise replace both records and local evidence.

Evidence type	Handling baseline - proposed
Audit events	Restrict write permissions to controlled services; prohibit ordinary edit/delete access; review gaps and failures.
Independent checkpoints	Export to a separate account/custodian, verify signatures and retention, and test retrieval during recovery.
Security logs	Record event category, actor reference, environment, outcome, request correlation and time; redact tokens, passwords, buyer details and callback secrets.
Forensic copies	Capture source, acquisition time, collector, SHA-256, access history and custody transfers. Preserve originals read-only.
Administrative exports	Limit recipients, encrypt transport and storage, retain a reason and expiry, and revoke temporary access after review.

Operational review

Monitor audit-write failures, chain mismatch, clock drift, unexpected privileged actions and missing worker heartbeats. A dashboard showing records is not proof of complete logging. Store evidence of daily checks and investigate when collection stops.

> I: chain and checkpoint generation. P/V: independent custody, immutable retention, privileged database restrictions and a measured detection process.

Private uploads and document review

Large evidence files require controlled staging, integrity checks and bounded processing.

The verification service accepts PDF, PNG and JPG up to 100 x 1024 x 1024 bytes, displayed as 100 MB. Upload sessions support bounded chunks; the general API request-size cap is separate from the total document limit. Proxy and PHP limits must align with the chosen upload path.

- Validate the document type, actual content and size. Stage files outside the public web root and bind upload sessions to the authorized registration/account context.
- Store content in authenticated encrypted frames; preserve plaintext length and SHA-256 metadata. Before reviewer exposure, decrypt and verify every byte against the expected size and digest.
- Version replacements independently. A newly uploaded current version requires a fresh review; previous copies and decisions remain in history.
- Authorize previews and downloads by owner or permitted reviewer. Record access where implemented and avoid public reusable document links.
- Remove expired unclaimed uploads through the scheduled cleanup; retain claimed evidence under the approved retention schedule.

Further hardening before production reliance - proposed

Add or verify malware scanning, quarantine decisions, resource limits and suspicious-content handling. File-type validation alone is not malware detection. Review PDF/image parser updates and isolate costly rendering. The current private-stream verifier may use temporary plaintext storage; verify host encryption, permissions, cleanup and capacity for that path.

Keep reviewers focused on the original evidence and recorded decision. Branding changes do not prove identity. Identity and tax-profile corrections follow review workflows; a direct profile-image update does not confer account verification.

> I: 100 MiB application limit, private frame storage and integrity checks. V: reverse-proxy limits, malware controls and operational review coverage.

Privacy, retention and controlled deletion

Retention must follow the applicable purpose, record class and approved legal basis.

Record class	Policy decision required
Financial originals and adjustments	Approve retention period, fiscal/legal obligations, legal holds and correction rules. Preserve provenance; do not silently rewrite posted financial history.
Registration and identity evidence	Define access, necessity, review retention, replacement history and secure disposal after permitted expiry.
Customer receipt data	Limit to receipt processing and authorized support; document the merchant relationship, notice, email provider and delivery retention.
Security and audit records	Set investigative retention and access controls. Retain incident/legal-hold material beyond ordinary expiry where authorized.
Sandbox and development data	Use synthetic or de-identified fixtures. Set automatic expiry where implemented and avoid importing production identity documents.
Backups and replicas	Specify lifecycle, legal holds, deletion lag and how deletion/restriction requests are honored after a restore.
Temporary files and exports	Minimize lifetime, use restricted storage and document download/export recipient responsibility.

Proposed deletion workflow: verify requester authority and scope, check holds and regulatory requirements, identify dependent records and copies, obtain the required approval, preserve authorized audit evidence, execute a scoped deletion and verify the result. Reconcile restored backups against the deletion register before re-opening access.

The owner's earlier test-account reset requests are not a general authorization to remove other merchants or statutory records. The manual does not prescribe one universal retention period; the DPO/legal owner and records owner must approve the schedule for the actual service and jurisdiction.

> P/V: privacy impact assessment, processing agreements, subprocessor register, retention schedule and data-subject request procedure.

Secure development and release procedure

Every production change needs a reproducible artifact and a bounded rollback plan.

Gate	Required evidence - proposed unless stated otherwise
Change definition	Problem, intended behavior, affected tenant/environment, data migration and compatibility impact.
Review	Peer review of access boundaries, financial logic, cryptography use and sensitive output. Separate high-risk approval from implementation where feasible.
Automated checks	Backend tests, frontend type/build checks, document-renderer tests, negative authorization and environment isolation. Record commands, revision and results.
Security validation	Dependency/SBOM review, secret scan, upload/SSRF controls, rate behavior and threat-specific tests. Do not treat a passing build as a security assessment.
Release package	Immutable build digest, dependency locks, migrations, rollback scripts, operator notes and documentation revision.
Deployment	Backup readiness, maintenance/traffic plan, reviewed configuration, migration execution and worker restart compatibility.
Verification	Read-only smoke checks, authenticated role checks, queue health, document rendering and environment separation; no unapproved Live sale.
Close / rollback	Record measured outcome, compare to acceptance criteria and roll back on defined triggers. Forward-fix irreversible schema/data changes only through a reviewed plan.

The security:deployment-check command evaluates basic configuration conditions such as HTTPS URL, debug setting, shared cache, durable queue, MFA, checkpoint key and reviewed-release reference. It explicitly cannot prove WAF effectiveness, least-privilege grants, key custody, high availability, correct restores, regulatory authority or measured capacity.

> I: a configuration-check command exists. P/V: release governance, automated pipeline enforcement and completed independent tests.

Operational routines and worker inventory

Scheduling declarations are not evidence that the server scheduler is running.

Work item	Declared cadence / behavior	Operator check
Internal EIS preparation	Every minute; creates missing internal records without network delivery	Backlog, conflicts and worker errors
EIS reconciliation	Every five minutes; internal reminders for exceptions and overdue cases	Uncertain/dead-letter work and owner assignment
Transactional notifications	Every minute, bounded work; dispatch flag controls external sending	Queue age, uncertain outcomes, sender health
Notification reconciliation	Hourly	Deduplication and reminder freshness
Merchant webhooks	Every minute, bounded runtime and overlap guard	Heartbeat, oldest pending event, delivery failures
MFA setup cleanup	Every ten minutes	Expired pending secrets erased
Unclaimed upload cleanup	Daily	Expired staging removed; claimed evidence preserved
Audit checkpoint	Explicit command; offsite export needs an operational process	Chain validity, signature and independent custody

Daily operator checklist - proposed

Review application availability, queue age, failed jobs, database capacity, wallet reconciliation, audit integrity, backup completion, restore-point freshness and security alerts. Confirm that alerts reach a staffed channel. Document exceptions with an owner and due time; do not clear red indicators merely by changing a status field.

Before maintenance, identify work in flight, pause only affected dispatchers, capture queue counts and preserve idempotency state. After maintenance, verify new commits and resume workers gradually. External email and webhook outcomes require their own evidence even if the application is healthy.

> I: routes/console.php defines these schedules. V: cron/service-manager configuration, effective time zone, worker supervision and real heartbeat evidence.

Monitoring and online/offline semantics

An indicator must name the dependency it actually measures.

Signal	Truthful meaning	Must not imply
Browser online	The browser reports a network interface/connectivity state	NUERS API or provider is reachable
NUERS responding	A defined application health/status request received a valid response	Database writes, receipts or external transport all work
Integrated	Accepted external Live intake with current eligible credentials	Real-time connectivity or BIR connection
Authenticated API ready	Current session/key and scoped status checks pass	Unlimited funds or issuance authority
Worker healthy	Heartbeat and bounded queue processing evidence are current	Every callback recipient is available
BIR readiness / outcome	Separate recorded eligibility/provider evidence	Success solely because NUERS accepted the sale
Backup / recovery ready	Current verified backup and restore evidence against policy	Readiness from a green server icon alone

Proposed operational dashboard

Track eligible request success, server errors, p50/p95/p99 latency, database lock time, queue age, worker heartbeat, failed/uncertain notifications, webhook dead letters, wallet discrepancies, storage capacity, certificate expiry and audit-chain failures. Break down metrics by environment and service, with tenant-level views limited to authorized staff.

The offline connector should retain its own durable outbox and show pending or unknown state clearly. Never display a sale as successfully recorded solely because it entered a local queue. Browser retry storage is not the authoritative ERP backup. The same principle applies when a page is cached or a previously healthy indicator is stale.

> P: display last-checked time and a stale state. Test DNS failure, offline mode, expired session, API 5xx and an unavailable callback independently.

Backup and recovery policy

Proposed baseline; actual recovery points and times must be measured in drills.

Asset	Proposed protection	Verification
Relational database	Scheduled encrypted full backups plus transaction-log / point-in-time recovery where supported	Restore to an isolated host; reconcile committed transaction and wallet totals
Private documents	Versioned encrypted copies coordinated with metadata and checksums	Restore and decrypt representative files; compare length and SHA-256
Application/configuration	Release artifacts, schema version and sanitized configuration inventory	Rebuild service and renderer from documented versions
Keys / secrets	Separate secure recovery custody with restricted access	Demonstrate decryption and signing without exposing key material
Audit evidence	Chain plus independently held signed checkpoints	Recompute restored chain and compare external checkpoint
Work queues	Durable inbox/outbox and attempt records in consistent backups	Reconcile uncertain side effects before resuming dispatch

Initial planning objectives are an RPO of at most 15 minutes and an RTO of at most four hours for the core service. These are proposed engineering targets, not achieved results or contractual commitments. Confirm cost, replication/log support, data volume, key recovery and staffing before approval.

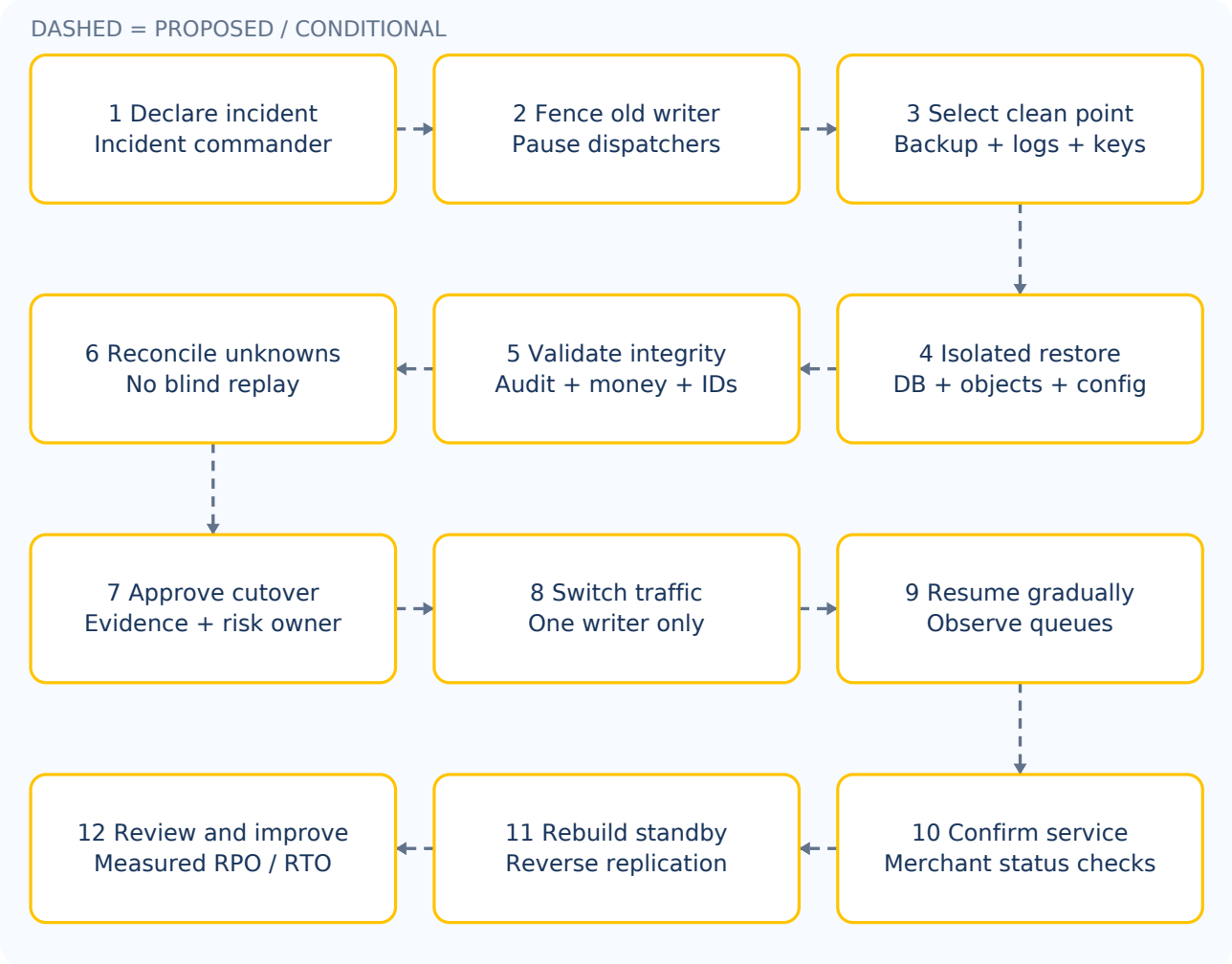
Use independent credentials and a separate administrative domain for offsite copies. AWS S3 Object Lock is a candidate for retention-protected object versions; mode, retention, lifecycle and recovery access require deliberate configuration and testing. Its availability does not mean it is enabled for NUERS. [R5]

Set daily backup verification, monthly sample restoration and quarterly full recovery exercises as an initial proposed schedule. Re-run after material schema, storage or encryption changes. The BCDR dashboard should record evidence and measured outcomes rather than manufacture successful backup jobs.

> P/V: backup schedule, immutable offsite custody, recovery objectives, runbooks and drill results. No completed recovery exercise is claimed in this edition.

Disaster-recovery sequence

D08 - A controlled single-writer recovery prevents split-brain and duplicate side effects.



Proposed sequence. The incident commander and service owner authorize cutover only after data, keys, identities and uncertain outcomes have been reconciled.

Recover database, private objects, application versions, configuration and keys as a compatible set. Confirm financial totals, audit integrity, source identities, document checksums, sequence positions and pending delivery records. Keep outgoing mail, webhooks and future BIR transport paused during isolated restore tests.

Measure RPO as the difference between the last source commit and the latest consistent recovered commit. Measure RTO from the agreed outage start to verified service restoration. Record any data-loss window and merchant reconciliation steps. A server boot time is not the full service recovery time.

> P: after restoration, verify revoked credentials and deletion/hold registers are applied. Failback is a new controlled change; do not reintroduce an unfenced old database writer.

Incident command and activation

A proposed operational plan aligned with the risk-management approach in NIST SP 800-61 Rev. 3. [R4]

Role	Responsibility
Incident commander	Declares severity, coordinates containment, records decisions and authorizes recovery with service ownership.
Technical lead	Scopes systems, preserves evidence, implements containment and validates remediation.
Security lead	Assesses compromise, attacker access, credential exposure and monitoring changes.
DPO / privacy lead	Determines personal-data impact, coordinates legal analysis and required notifications.
Service / finance owner	Assesses transaction, wallet and merchant impact; approves financial reconciliation.
Communications lead	Maintains factual internal/customer updates, approval records and next-update time.
Evidence custodian	Maintains timeline, hashes, original evidence, access logs and custody transfers.
Provider liaison	Raises provider tickets, tracks region/platform incidents and preserves provider evidence.

Activation triggers

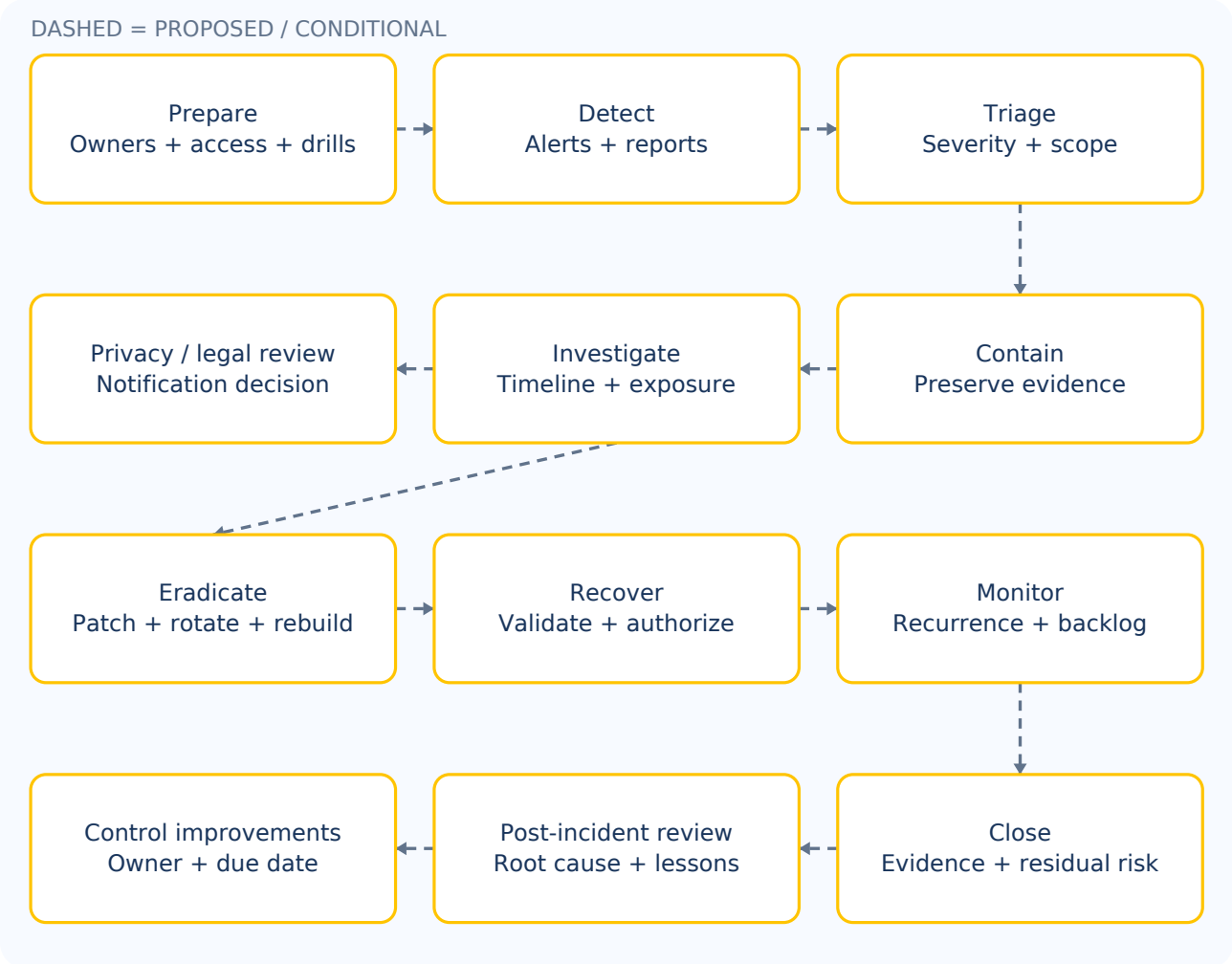
Activate for suspected unauthorized access, tenant-data exposure, key compromise, financial-integrity mismatch, ransomware, loss of critical data, sustained service outage or an unsafe external-delivery path. Begin a timestamped incident record even when scope is uncertain. Preserve the distinction between a security incident and a confirmed personal-data breach.

Assign actual names, backups, contact routes and authority limits before adoption. Do not put private phone numbers or emergency secrets in a widely distributed manual. Keep the current roster in a restricted operational system accessible during a primary-platform outage.

> P: these roles and procedures are an operating proposal. Naming them in this manual does not establish a staffed 24/7 response capability.

Response workflow

D09 - Preserve evidence, contain impact and recover through explicit validation.



Proposed incident lifecycle. Privacy/legal assessment runs alongside containment and technical investigation; it must not wait for complete root-cause certainty.

At triage, record detection time, first known occurrence, affected environment, systems, tenants, data classes and current customer impact. Distinguish confirmed facts from hypotheses. Use a restricted incident channel and document every privileged containment action.

Recovery requires evidence that the cause is removed or controlled and that integrity checks pass. Continue heightened monitoring after reopening traffic. Close only when the service owner accepts residual risk, communications are complete and corrective actions have owners and deadlines.

> P: perform a tabletop exercise before launch and after major architectural changes. Review missed detections, response friction, data reconciliation and communications in each exercise.

Severity and first-response playbooks

Proposed response targets require staffing approval and a tested escalation route.

Severity	Examples	Initial target / update
SEV1 - critical	Confirmed broad compromise, material financial corruption or core service unavailable	Acknowledge within 15 min; updates every 30 min
SEV2 - high	Significant tenant impact, suspected key exposure or growing critical backlog	Acknowledge within 30 min; updates hourly
SEV3 - moderate	Limited degradation with a workable alternative and no confirmed data exposure	Acknowledge within 4 business hours; daily updates
SEV4 - low	Routine defect, request or documentation issue	Acknowledge within 1 business day; agreed schedule

IR-01: stolen API credential or account takeover

Identify the affected account, key and environment. Revoke the exposed key or session, preserve relevant access and transaction records, and check recent source events, changes to callback endpoints and team grants. Contain the source of exposure before issuing replacement credentials. Reconcile accepted events with the merchant; never erase evidence to hide fraudulent activity.

IR-02: malicious callback or SSRF attempt

Pause or revoke the endpoint and preserve configuration history, delivery IDs, resolved destinations and sanitized error metadata. Check egress logs for forbidden access and whether DNS pinning or destination validation was bypassed. Verify all endpoints owned by the affected account and retest the fix in isolation before reactivation.

> P: these acknowledgement times are targets for an approved support model. They are not resolution guarantees or a statement that on-call coverage is already contracted.

Financial integrity and outage playbooks

Protect accepted records and prevent a recovery action from creating another incident.

IR-03: wallet or duplicate-transaction mismatch

Freeze the affected write path if continued processing risks further inconsistency. Preserve the intake identity, canonical hash, acceptance result, transaction/receipt IDs, fee policy, wallet entries and audit events. Compare the merchant source outbox to accepted NUERS records. Determine whether the anomaly is a display/query issue, a rejected request, an unknown outcome or an actual ledger discrepancy. Use a reviewed adjustment or corrective release; do not patch posted balances directly.

IR-04: ransomware or suspected host compromise

Isolate the affected host and credentials without destroying volatile evidence. Stop untrusted replication from overwriting clean recovery material. Identify the earliest trustworthy restore point and independent keys/checkpoints. Rebuild from known artifacts in an isolated environment, validate integrity, rotate exposed credentials and perform privacy review. A clean antivirus result alone is insufficient recovery evidence.

IR-05: regional/provider outage or database failure

Declare impact, preserve available failure evidence and confirm whether the outage is transient. Fence the old writer before standby promotion. Restore a compatible database/object/key set, reconcile uncertain external side effects and verify balances, sequences and audit chain. Switch traffic only after the authorized recovery decision, then resume workers gradually.

IR-06: receipt email sent to the wrong recipient

Pause affected mail processing, preserve recipient source and delivery state, identify the exposed document/data classes and prevent further copies. Assess whether a source input, tenant boundary or rendering bug caused the event. Route to the privacy lead and correct the cause before an authorized resend. SMTP acceptance does not prove recall is possible.

> P: each playbook must name an owner, preserve a timeline, define a rollback/stop condition and capture verification evidence. Do not use production financial writes as a diagnostic shortcut.

Breach assessment and communications

Privacy reporting is a qualified legal workflow, not an automatic message for every technical error.

The Philippine National Privacy Commission describes mandatory notification criteria involving sensitive or identity-fraud-enabling information, reason to believe an unauthorized person acquired it, and a real risk of serious harm. Its guidance provides a 72-hour notification window upon knowledge of or reasonable belief in a qualifying personal-data breach. The DPO/legal lead must assess applicability, current rules, recipients, channel and timing promptly. [R7]

Decision record	Required content - proposed
Detection and scope	What happened, when discovered, affected systems/environment, data categories, known persons/tenants and uncertainty.
Notification assessment	Applicable rule, facts supporting or rejecting notification, accountable decision-maker, deadline and next reassessment time.
Containment	Actions taken, credentials revoked, services paused and remaining exposure.
Recipient communication	Facts, likely impact, protective action, contact route and next update. Avoid speculation or secret/customer data in broad messages.
Regulator / contractual notices	Approved notice, submission reference, evidence of timing and follow-up obligations. Track provider and merchant contract requirements separately.
Closure	Root cause, affected scope, remediation, lessons and accepted residual risk.

Proposed initial customer update: "We are investigating an issue affecting [service/environment] since [time and zone]. Known impact: [confirmed facts]. Current action: [containment]. Customer action: [specific instruction or none]. Next update: [time]. Reference: [incident ID]." Obtain the designated approval without delaying legally required notifications.

> P/V: appoint the privacy lead, maintain current legal guidance and test notification access before an incident. This manual is an operational framework and does not replace case-specific legal assessment.

Service catalogue and accountability

Separate the NUERS service from dependencies and outcomes outside its direct control.

Service	Responsibility and measurement boundary
Merchant portal	Authenticated access to owned business records and available functions. Measure usable requests and user-visible errors.
Transaction intake/status API	Authenticate, validate and durably record an eligible event or return a truthful rejection. Measure the documented API endpoint boundary.
Document view / PDF	Render the stored financial record with permitted branding. Measure successful authorized rendering and generation time.
Customer receipt email	Queue and attempt an eligible receipt email. Measure queue/SMTP outcomes separately from customer inbox delivery.
Merchant webhooks	Deliver signed events to an active verified receiver using bounded retry and visible outcomes. Receiver availability is a separate dependency.
Wallet and fee records	Maintain auditable fee and balance movements; expose recorded totals and exceptions.
Reports / exports	Produce scoped records and totals consistent with filters and environment.
Government transport	Excluded from an operational promise until authoritative interface, eligibility, provider and agreement are established.

Proposed agreement structure

Define service hours, support timezone, covered endpoints, exclusions, maintenance notice, severity model, escalation, measurement source, reporting period, remedies and data exit. The commercial agreement must name the actual accountable entity and support contacts. Specify how disputes about availability and transaction outcomes are resolved using evidence.

Provider uptime commitments do not automatically become NUERS application commitments. Likewise, a healthy application does not prove a merchant's internet connection, email mailbox, callback receiver or government system is available.

> P: this chapter is a framework for a future approved SLA and internal SLOs, not a signed agreement or a guarantee of availability.

Proposed SLIs, objectives and budgets

Targets become commitments only after measurement, staffing, testing and management approval.

Indicator	Definition	Initial proposed objective
Core API availability	Successful eligible intake/status service outcomes / eligible attempts, measured at the service boundary	99.9% monthly
Interactive latency	p95 for a defined representative single-event workload under approved load; excludes third-party delivery	2 seconds target; load envelope must be tested
Document rendering	p95 for agreed document size/template on the deployed renderer	10 seconds target; benchmark required
Dispatch freshness	Time from committed intent to first worker attempt when enabled and endpoint eligible	95% within 2 minutes
Financial correctness	Unexplained duplicate debit or accepted-identity conflict	Zero tolerated; every occurrence investigated
Recovery point	Latest consistent recovered commit relative to source	At most 15 minutes, subject to drill
Recovery time	Agreed outage start to verified service restoration	At most 4 hours, subject to drill

For a 30-day month, a 99.9% time-based availability objective permits 43 minutes 12 seconds of unavailability. The request-based SLI above has a separate error budget of 0.1% of eligible attempts. Do not interchange request-based and time-based calculations in service reports.

Classify expected validation/authentication/business rejections separately from server failures. An invalid payload or insufficient wallet is not automatically a platform outage, but an incorrectly rejected valid request is a service defect. Capture timeouts and unknown outcomes; do not hide them by counting only received 2xx responses.

> P: agree maintenance treatment and exclusions in writing, keep raw measurements, and review error-budget burn. No performance or availability benchmark was executed to establish these proposed numbers.

Support, maintenance and service review

A support process needs clear ownership, a clock and an evidence trail.

Support intake - proposed

Collect incident/request ID, tenant reference, environment, affected operation, time and timezone, sanitized error, correlation/transaction ID and business impact. Do not collect API secrets, MFA codes, full customer documents or unrestricted database exports in an ordinary ticket. Route security/privacy reports to the restricted response team immediately.

Process	Proposed operating rule
Coverage	Approve staffed service hours and an emergency route. Do not advertise 24/7 support until staffing and escalation are contracted and tested.
Planned maintenance	Provide at least 48 hours' notice for material planned interruption where feasible; disclose scope and expected duration. Emergency security changes use the incident route.
Escalation	Service desk to technical owner to incident commander/service owner. Unacknowledged SEV1 alerts escalate through a tested secondary route.
Change communication	State behavior changes, API compatibility, migration steps, deprecation dates and documentation version.
Monthly review	Availability, latency, incidents, queue delivery, backup/restore evidence, wallet reconciliation, access reviews and overdue actions.
Exit / portability	Verify authorized export, data format, retained records, key/secret revocation, support closure and provider deletion evidence.

Keep a status history with incident start/end, affected services and the measurement basis. Report estimated recovery as an estimate, not a guaranteed time. Record separately the point when service returns and the point when all delayed notifications or financial reconciliations finish.

> P: contractual remedies, service credits, liability, retention commitments and mandatory notices must be finalized by the business and legal owners.

Merchant administration workflow

A concise end-to-end procedure for business owners and authorized staff.

Step	Action and expected result
1. Access	Use a registered email and authorized login. Complete MFA for the login; keep recovery codes private. Add an independent authenticator device through Account Security when needed.
2. Business profile	Maintain permitted contact details, website and description. Submit identity/tax changes for administrative review. Update the profile image separately from receipt branding.
3. Documents	Upload the required evidence; inspect status and review notes. A replacement is a new reviewable version, not a change to the prior decision.
4. Integration	After account eligibility is satisfied, copy assigned connection metadata, create an environment-specific key and store the secret on the ERP/POS backend.
5. Sandbox	Submit synthetic cases, test duplicates and errors, and confirm that no Live balance, report or customer email is affected.
6. Receipt settings	Upload the dedicated invoice/receipt logo, select permitted layout and save. Preview and download a copy to verify branding.
7. Live operation	Keep sufficient wallet funds; submit stable source events and display NUERS success or the returned error reason in the source system.
8. Follow-up	Review status, email outcomes, webhook attempts, reports and exports. Escalate uncertain outcomes with record IDs, not secrets.

The connector should show pending/unknown until it has an authoritative result. Rejected events should display a useful operator-facing reason. A background retry must not conceal a persistent error or create another external reference. Merchant sales reports should use the selected date, environment and sale category consistently.

> I: workflow capabilities are reflected in the reviewed portal/services. V: screenshots, actual permission assignments and deployment-specific menu wording may differ until the release is verified.

Administrator and finance workflow

Control identity, evidence and money without confusing account activation with external authority.

- Review the registered merchant and uploaded document versions. Open the evidence, record an independent decision and use a factual reason. Keep the reviewer and timestamp.
- Approve account access and onboarding only through the authorized workflow. An already active/onboarded account should not be presented as requiring a duplicate account approval merely because a generic document banner is stale.
- Process proposed identity/profile corrections with the appropriate evidence. Synchronize the approved owner/representative display through the supported workflow; do not directly alter unrelated user records.
- Inspect connected merchant source profiles, API environments and status. Default owned-system metadata does not authorize an unrelated historical source or government issuance.
- Configure the transaction minimum and fee with a reason. A minimum of zero charges every new eligible Live primary sale at the configured fee; reconcile actual charged amounts from the ledger.
- Review deposits and wallet adjustments with the required approvals and evidence. Separate available balance, deposited funds and recorded fee revenue in reports.
- Use filters and exports consistently: business, date range/timezone, environment, document type, status and applicable sales-benefit category. Verify pagination stays below the table and does not alter the exported scope.

Report and export governance

Senior citizen, PWD, national athletes/coaches, solo parent and manual-discount data must preserve their recorded bases and financial amounts. A category label alone is not a legal eligibility decision. Use the current calculation and integration contract, document source evidence and avoid combining supplementary payment receipts with primary invoices as new sales.

> P: periodically compare dashboard totals, detailed exports and ledger queries for the same filter context. Maintain export access logs and an approved recipient policy.

Test strategy and acceptance evidence

A detailed manual must identify how its claims will be verified.

Test family	Minimum scenarios
Authorization	Cross-tenant reads/writes, role downgrade, team limits, object-ID guessing, exports, revoked sessions and keys.
Identity / MFA	Unknown Google email, mismatched subject, single-use handoff, replayed TOTP, expired setup, five-device limit and recovery-code reuse.
Financial correctness	Zero/positive fee threshold, exact boundary, insufficient funds, concurrent requests, rounding, manual discounts, mixed tax and sales-benefit cases.
Durable intake	Same identity/same content, changed content conflict, timeout after commit, crash before commit, batch rollback and unchanged retry.
Environment	Live/Sandbox status visibility, reports, wallet, numbering, email suppression and callback separation.
Documents	Large upload, corrupt frame/hash, unauthorized preview, replacement history, independent logo and shared PDF rendering.
Delivery	Valid/invalid signature, replay, private DNS, redirect, timeout, rotation, dead letters, mail uncertainty and worker restart.
Recovery	Restore database/objects/keys, audit checkpoint, lost-write window, stale credentials, deletion register and paused side effects.

Record release digest, environment, test data classification, commands, expected/actual outcomes, timestamps and evidence locations. Use isolated synthetic fixtures for destructive and failure-injection tests. A repository test file proves only that a test exists; a dated successful run and its scope are required for a release claim.

> V: no new full application test suite, penetration test, capacity benchmark or live recovery drill was executed solely to produce this manual. PDF layout/content validation is a separate document-quality activity.

Deployment readiness and risks

Resolve these items before representing the planned architecture as production-assured.

Priority / item	Required closure evidence	Accountable role
Critical: actual hosting/residency	Signed provider/region register for app, database, objects, backups, logs, keys and support	Service owner + DPO
Critical: recovery and key custody	Independent restoration, measured RPO/RTO, key recovery and fenced failover test	Platform + security
Critical: official transport claims	Authoritative provider specification, credentials, eligibility and authentic acknowledgement tests	Compliance + integration
High: operational staffing	Named on-call roster, escalation drill, incident contacts and approved SLA scope	Service owner
High: external customer delivery	Mail setup/domain evidence and real authorized receiver verification; privacy/data-location record	Operations + merchant
High: runtime hardening	TLS/firewall review, origin restriction, DB grants, storage encryption and secret handling	Platform + security
High: independent assurance	Negative access tests, vulnerability review, dependency inventory and remediation records	Security lead
High: capacity and monitoring	Agreed load envelope, measured performance, alerts, queue limits and restore capacity	Engineering + operations
Medium: governance	Retention schedule, access reviews, control approvals and documentation/version ownership	Records owner + DPO

Do not turn these items into green status simply by approving the document. Each requires evidence from the actual deployment, responsible operator or external authority. Record compensating controls and expiry for any accepted exception, and revisit the risk after material changes.

> I/P/V separation is intentional: application capability, a proposed policy and deployed assurance are different evidence levels.

Operating approvals and ownership

Use this page to adopt the proposed controls only after the identified evidence is available.

Approval area	Named owner / approval reference	Status in this edition
Software release baseline	Engineering owner and immutable release digest	To be recorded
Hosting and data location	Service owner and signed deployment register	Planned; allocation unconfirmed
Security / key custody	Security owner and control evidence pack	To be reviewed
Privacy and retention	DPO/legal owner and processing/retention register	To be reviewed
Incident response	Incident commander roster and completed exercise	Proposed
Business continuity	Recovery owner and independent restore evidence	Proposed targets; unmeasured
Service levels	Business owner and executed service agreement	Framework only
Government interface	Authorized compliance/integration owner and provider evidence	Default software transport blocked
Document release	Document controller, review date and distribution list	Prepared for review

A signature or approval reference should identify the scope accepted, unresolved exceptions, evidence location and next review date. Do not sign on behalf of an unassigned role. A reviewer can approve the manual as an accurate baseline while leaving the proposed hosting or SLA decisions pending.

Change triggers

Review this manual after an API/schema change, new provider or region, data-store migration, encryption/key change, authentication change, material incident, recovery exercise or revised legal/contractual requirement. Keep the website guidance, merchant connection PDF, OpenAPI schema and deployed behavior aligned with a common release record.

> P: suggested review cycle is quarterly and after material change. Retain superseded editions with their evidence references; remove outdated public copies when replacements are published.

Implementation source index

Reviewed source areas supporting the I labels in this manual.

Topic	Repository evidence
Stack and build	composer.json; package.json; scripts/build-document-renderer.mjs
HTTP and access	app/Http/Middleware/ApiBoundary.php; SecurityHeaders.php; app/Services/ApiAccess.php; MerchantTeamAccess.php
Login / MFA	app/Http/Controllers/Auth/GoogleAuthController.php; app/Services/MfaSession.php; MfaDevices.php; Totp.php; docs/knowledge/mfa-login-session.md
API ingestion / pricing	app/Http/Controllers/Api/IntegrationTransactionController.php; app/Services/IntegrationContract.php; TransactionPricing.php; MerchantWallet.php; SandboxTransactions.php
Merchant setup	app/Services/MerchantApiContext.php; MerchantApiOnboarding.php; MerchantSystemIntegration.php; IntegrationSourceProfile.php
Documents / mail	app/Services/ElectronicDocumentView.php; MerchantInvoiceSettings.php; DocumentPdf.php; ApiCustomerReceipt.php; PlatformNotifications.php
Evidence files	app/Services/MerchantVerificationDocuments.php; PrivateDocumentStream.php; app/Http/Controllers/Api/VerificationUploadController.php
Callbacks	app/Services/MerchantWebhooks.php; MerchantWebhookTransport.php; WebhookDestination.php; SignedWebhook.php
Audit / government / recovery	app/Services/BirCompliance.php; Eis/BlockedProvider.php; EisDelivery.php; EisDocumentReadiness.php; BackupRecovery.php
Schedules / configuration	routes/console.php; config/security.php; config/app.php; config/queue.php; config/session.php
Contract and guide	docs/integrations/merchant-ingestion-1.md; resources/data/developer-openapi.json; src/lib/integrations/merchant-guide.ts

This index refers to the workspace reviewed on 19 October 2026. The workspace contains evolving changes; version 1.0.0 is the declared software label, not a substitute for a reproducible release digest. A separate source-evidence manifest accompanies the editable production source and records hashes of selected files used for this edition.

> Evidence method: read-only source inspection and official-reference review. Production configuration, private credentials and live customer records were not extracted for this manual.

External reference register

Primary references checked on 19 October 2026; confirm current guidance when adopting the plan.

Ref	Source and use
R1	**AWS Regions** - region codes and opt-in facts. docs.aws.amazon.com/global-infrastructure/latest/regions/aws-regions.html
R2	**Dataplugs Data Centers** - published Hong Kong location options. dataplugs.com/en/company/data-center/
R3	**Contabo: Hello from Singapore** - published Singapore launch. Current service/order availability still requires confirmation. contabo.com/blog/hello-from-singapore/
R4	**NIST SP 800-61 Rev. 3** - incident response within cybersecurity risk management, published April 2025. csrc.nist.gov/pubs/sp/800/61/r3/final
R5	**AWS S3 Object Lock** - candidate retention-protected object storage mechanism. docs.aws.amazon.com/AmazonS3/latest/userguide/object-lock.html
R6	**OWASP Transport Layer Security Cheat Sheet** - proposed TLS hardening baseline. cheatsheetseries.owasp.org - Transport Layer Security
R7	**National Privacy Commission: Breach Reporting** - qualified notification criteria and reporting process. privacy.gov.ph/pips-and-pics/breach-reporting/

External references support provider facts and general control guidance. They do not establish a NUERS contract, deployed service, certification, legal opinion or achieved objective. Contabo's page was available through indexed provider material; direct access returned a restriction during review, so current procurement details remain unverified.

> The operational procedures and proposed numeric targets are authored for this manual. They are not presented as quotations or mandatory targets prescribed by the referenced sources.

Incident and recovery evidence forms

Use these field sets in the controlled operations system; do not place secrets in the record.

Incident record	Required fields
Identity	Incident ID; severity; commander; technical/security/privacy owners; environment; detection time and timezone.
Impact	Affected services, tenants and data classes; first/last known occurrence; confirmed facts; unknowns; business impact.
Timeline / evidence	Timestamped actions; request/event IDs; evidence location and hash; custodian; access/transfer record.
Containment / recovery	Paused/revoked resources; decisions and approvers; restoration point; verification results; residual risks.
Communication / close	Notification assessment and deadline; sent-message references; next update; root cause; corrective actions and due dates.

Recovery exercise record	Required fields
Scope and source	Scenario; release/schema versions; backup IDs; database commit point; object inventory; key version references.
Execution	Isolated destination and region; outbound delivery controls; operator; start time; restore steps; errors.
Validation	Record counts/totals; wallet reconciliation; audit checkpoint; document hashes; session/key revocation; sequence and pending-work checks.
Measured outcome	Source/recovered commit timestamps; actual RPO; outage/restored-service timestamps; actual RTO; exceptions.
Approval	Independent reviewer; pass/fail basis; follow-up owners; next exercise date; evidence retention location.

P: templates are ready for adoption, not populated proof of an incident or successful recovery. Keep any populated forms in restricted storage and distribute only redacted summaries externally.

Glossary

Terms used throughout the technical specification and operating manual.

Term	Meaning
API / ERP / POS	Application programming interface / enterprise resource planning / point of sale.
BIR / EIS / ESP	Bureau of Internal Revenue / Electronic Invoicing System / Electronic Software Provider; authority and accreditation require their own evidence.
DFD / lineage	Data-flow diagram / trace of origin, transformation, identifiers and derived outputs.
Idempotency	Repeated processing of the same accepted event returns one stored result rather than another financial effect.
Inbox / outbox	Durable intake record / durable intent for later delivery or processing.
MAC / HMAC / TOTP	Message authentication code / keyed hash MAC / time-based one-time password.
RPO / RTO	Recovery point objective (data-loss window) / recovery time objective (service restoration duration).
SLI / SLO / SLA	Service-level indicator / internal objective / contractual agreement.
DPO / PIC / PIP	Data protection officer / personal information controller / personal information processor.
WAF / KMS / SBOM	Web application firewall / key management service / software bill of materials.

A successful local transaction, an issued original, a prepared internal model, a transmitted message and an acknowledged external result are different states. Always identify the boundary and evidence before using the word success in a report or service commitment.

> Use the definitions consistently in merchant interfaces, operator runbooks, API documentation and incident communications.

Production notes and edition history

Supporting assets, authorship method and maintenance of the controlled manual.

Production and visual provenance

Official NUERS logo assets and the navy/blue/gold palette were reused from the project. The conceptual cover artwork was created with the built-in image-generation tool. The nine technical diagrams are original vector diagrams drawn from reviewed source behavior and explicitly labeled proposals. No generated illustration is evidence of a deployed data center.

The cover asset and exact prompt are retained in output/technical-manual/assets/. The editable PDF builder and selected-source hash manifest are retained with this manual's production files. The PDF uses searchable text, internal navigation, vector diagrams and mirrored binding margins.

Asset	Location / method
Cover illustration	output/technical-manual/assets/secure-transaction-architecture.png | Built-in image generation, new image.
Prompt provenance	output/technical-manual/assets/image-provenance.txt | Exact final prompt, mode and intended use.
Official logo	public/auth-assets/nuers-digital-logo.png and nuers-digital-white.png | Reused project assets, not generated logo replacements.
Technical figures	D01-D09 | Original code-drawn vector diagrams; editable in build_manual.py.
Source baseline	output/technical-manual/source-evidence-manifest.json | SHA-256 of selected local source files, generated for this edition.

Edition history

1.0 - 19 October 2026: Initial technical specification and system manual for declared software version 1.0.0. Covers the implemented application baseline, end-to-end processing, lineage, planned hosting, security, incident response, recovery and proposed service-level framework.

For a revised edition, update the technical evidence, source hashes, page navigation, visual diagrams and approval status together. Preserve the previous edition as a historical record and use a documented distribution process for the replacement.

> End of manual | NUERS 1.0.0 | Edition 1.0 | Prepared 19 October 2026. Review the control page before treating a printed copy as current.